

Full length article

A modeling and optimization framework for adaptive countermeasure selection in reaction against cyber attacks

Pantaleone Nespoli ^a, Pedro Beltrán-López ^a,* , Giancarlo Sperli ^b

^a Department of Information and Communication Engineering, University of Murcia, Murcia, Spain

^b Department of Electrical Engineering and Information Technology (DIETI), University of Naples Federico II, Via Claudio 21, Naples, Italy

ARTICLE INFO

Keywords:

Cyber defense
Countermeasure selection
Reaction frameworks
Decision support
Countermeasure modeling
Empirical benchmark

ABSTRACT

Selecting appropriate countermeasures against cyber attacks is a challenging problem since the optimal response must balance risk reduction, operational impact, and execution time. Previous work addressed this problem through three complementary elements, i.e., a standardized representation of countermeasures, an Artificial Immune System (AIS)-based selector, and a Genetic Algorithm (GA)-based calibration stage. This article preserves those foundations while extending the framework in two directions. First, it introduces an explicit asset–threat–countermeasure formulation of the problem, including a baseline residual risk model and an extended operational variant that captures deployment dependencies among countermeasures. Second, it broadens the empirical assessment through a comparative evaluation of alternative decision strategies under a common experimental setting, including deterministic baselines and stochastic search methods. The evaluation was conducted on synthetically generated scenarios ranging from 15 to 400 assets, 30 to 1000 threats, and 40 to 1200 candidate countermeasures, comparing 8 algorithms under repeated executions. The results show that, under the baseline residual risk formulation, Greedy Incremental provides the strongest overall performance among the evaluated strategies. Under the extended operational formulation, however, Hybrid AIS-GA becomes more robust, achieving lower residual risk and reduced variability than the strongest deterministic baseline while maintaining operationally feasible execution times. These findings provide a more scalable and expressive basis for adaptive countermeasure selection and show that the practical value of a decision strategy depends strongly on the structure of the problem.

1. Introduction

Modern ICT infrastructures support critical services for governments, enterprises, and citizens, while remaining continuously exposed to cyber attacks that are increasingly sophisticated, disruptive, and difficult to contain (Nespoli et al., 2026; Canonico and Sperli, 2023). However, detecting malicious activity is not sufficient on its own. Effective cyber defense must also incorporate proactive countermeasures and response capabilities throughout the organizational lifecycle (Marchioro et al., 2026). Hence, once a threat has been identified, defenders must determine how to react, which countermeasures should be enforced, and whether the selected response achieves an adequate balance between protection, operational impact, and execution time (Bashendy et al., 2023).

This challenge is further relevant in cyber defense reaction, where the defender must decide how to counteract vulnerabilities or ongoing attacks under incomplete information, budget limitations, timing constraints, and possible side effects on the protected infrastructure (Randieri and Tomazzoli, 2025). Consequently, countermeasure

selection naturally emerges as a multi-criteria decision problem in which the most aggressive response is not necessarily the most appropriate one (Yue et al., 2025a). Instead, the selected reaction should reduce the risk affecting the relevant assets while preserving the operational viability of the system and avoiding unnecessary collateral damage (Luo, 2025; Li et al., 2020).

Nevertheless, the reaction ecosystem has historically received less attention than the detection one. One of the main reasons is the intrinsic complexity of cyber-defense response, which requires combining threat-related information, system knowledge, and remediation intelligence into a coherent decision-making process (Bozorgchenani et al., 2024; Gonzalez-Granadillo et al., 2020). Another important limitation is the lack of a broadly adopted representation for countermeasures. While vulnerabilities, weaknesses, attacks, and other security artifacts have benefited from important standardization efforts (Taherdoost, 2022), remediation knowledge remains comparatively under-formalized, which hinders interoperability, knowledge sharing, and reproducibility across reaction methodologies (Li et al., 2020).

* Corresponding author.

E-mail addresses: pantaleone.nespoli@um.es (P. Nespoli), pedro.beltranl@um.es (P. Beltrán-López), giancarlo.sperli@unina.it (G. Sperli).

To address this problem, previous work developed a research line around three complementary ideas. First, a standardized representation of countermeasures was proposed in order to describe remediation objects in a machine-readable and interoperable way (Nespoli et al., 2021b). Second, an Artificial Immune System (AIS)-based methodology was introduced to select sets of atomic countermeasures by modeling threats as antigens and candidate remediation sets as antibodies, while guiding the decision process through countermeasure benefit and acceptable risk rather than through blind risk minimization (Nespoli et al., 2021c). Third, this selector was later complemented with a Genetic Algorithm (GA)-based calibration stage to optimize the main AIS input parameters under a joint quality-time criterion (Nespoli et al., 2021a).

The problem addressed in this article can be stated as follows. Even if adaptive countermeasure selection has already been explored through cost-aware reasoning, probabilistic attack models, autonomous mitigation, reinforcement learning, and multi-objective optimization, the field still lacks a sufficiently explicit and comparable formulation that simultaneously models assets, threats, and countermeasures, supports residual risk evaluation under operational dependencies, and enables systematic comparison across alternative decision strategies.

Although these contributions established a solid basis for adaptive reaction against cyber attacks, they do not fully resolve three concrete shortcomings. First, while mature standards already exist for vulnerabilities, weaknesses, attack knowledge, and threat-intelligence exchange, remediation knowledge is still not represented with the same degree of structure and interoperability, which limits the systematic reuse of countermeasure knowledge across reaction workflows (Taherdoost, 2022; Nespoli et al., 2021b; Boyes and Higgins, 2024). Second, existing countermeasure-selection approaches already cover cost-aware reasoning, probabilistic attack models, autonomous mitigation, reinforcement learning, and multi-objective optimization (Li et al., 2020; Bozorgchenani et al., 2024; Gonzalez-Granadillo et al., 2020), but they typically rely on heterogeneous and often domain-specific abstractions. As a consequence, the literature still lacks a common formulation that explicitly links assets, threats, and countermeasures while supporting residual risk computation in a consistent and scalable manner [1, 14, 15]. Third, empirical validation is still commonly centered on individual methods or application-specific settings, which makes it difficult to compare adaptive optimization strategies against simpler baselines under a shared experimental perspective (Nespoli et al., 2026; Rezapour et al., 2024; Boyes and Higgins, 2024). These shortcomings motivate the need for a broader formulation that is expressive enough for realistic scenarios, computationally practical for larger countermeasure spaces, and supported by a comparative evaluation framework able to benchmark alternative decision strategies consistently.

Motivated by these shortcomings, this article presents a modeling and optimization framework for adaptive countermeasure selection in reaction against cyber attacks. The article builds on the earlier AIS-based selector and the GA-based calibration stage while contributing in two main directions. First, it introduces an explicit asset-threat-countermeasure formulation together with a revised residual-risk computation scheme. This provides a more systematic basis for modeling remediation knowledge and deployment dependencies. Second, it broadens the empirical assessment through a comparative evaluation of alternative decision strategies under a common experimental setting, with particular attention to solution quality, execution time, robustness, and scalability.

The main contributions of this article are summarized as follows:

- A modeling and optimization formulation for countermeasure selection based on explicit assets, threats, and countermeasures, including both a baseline residual risk model and an extended operational variant for studying deployment dependencies and interaction effects.
- A comparative experimental setting for assessing alternative decision strategies under a common perspective, including deterministic baselines and stochastic search approaches.
- An empirical analysis of the trade-offs between solution quality, execution time, robustness, and scalability, highlighting how algorithmic behavior changes with the structure of the countermeasure-selection problem.

The remainder of this article is organized as follows. Then, Section 2 presents the necessary background and related work. Next, Section 3 revisits the inherited conceptual foundations of the research line, whereas Section 4 presents the proposed formulation and its comparative evaluation. Then, Section 5 provides an overview of the experiments, while Section 6 describes the extended experimental evaluation and reports the obtained results. Section 7 discusses their implications and limitations. Finally, Section 8 concludes the paper and outlines possible future research directions.

2. Background and related work

The cyber defense process is commonly described as a cycle comprising prevention, detection, reaction, and forensics (Sánchez-Zas et al., 2026; Kotenko, 2025). Within this cycle, the reaction phase plays a particularly delicate role because it is the stage in which defenders must decide how to counteract a threat and how to restore the system to an acceptable protection level (Cardellini et al., 2022). Such a step requires selecting countermeasures that are effective enough to mitigate vulnerabilities or ongoing attacks while also limiting their possible negative side effects on the protected infrastructure. As a result, adaptive reaction naturally emerges as a multi-criteria decision problem in which effectiveness, impact, cost, timing, and contextual constraints must be considered jointly (Bozorgchenani et al., 2026).

Despite its relevance to the overall system security posture, the reaction ecosystem has historically received less attention than the detection one (Rezapour et al., 2024). In this sense, one could argue that this difference is mainly due to the complexity of cyber defense response, the need for adaptability in dynamic environments, and the greater difficulty of empirically validating reaction methodologies (Sánchez-Zas et al., 2026). In addition, the quality of any reaction strategy strongly depends on the remediation knowledge available to the defender (Kotenko et al., 2018). That is, if such knowledge is incomplete, weakly structured, or difficult to share across systems and teams, the practical value of the resulting methodology is inevitably limited (Jorquera Valero et al., 2021).

Throughout this section, the main concepts and related works underlying the present study are reviewed in detail. Specifically, Section 2.1 discusses the problem of countermeasure selection in the reaction ecosystem and revisits representative approaches proposed in the literature. Then, Section 2.2 examines the role of security standards and structured knowledge resources, highlighting their relevance for interoperability, automation, and reaction-oriented decision making. Finally, Section 2.3 focuses on adaptive optimization strategies and identifies the main research gap addressed by this article, thus motivating the modeling and optimization framework introduced in the following sections.

2.1. Countermeasure selection in reaction

Several research efforts have addressed the problem of countermeasure selection from different perspectives, confirming that reaction against cyber attacks is inherently a decision-making problem in which security improvement must be balanced against operational constraints (Guo et al., 2020). Early and recent surveys dealing with Intrusion Response Systems (IRSs) and reaction ecosystem alike agree that, unlike detection, response requires reasoning about the effects

of possible defensive actions, their timing, their cost, and their impact on the protected environment (Bashendy et al., 2023; Rezapour et al., 2024; Nespoli et al., 2026; Schlette et al., 2021). Such a challenge makes countermeasure selection a particularly challenging task, especially in dynamic scenarios where defenders must react under uncertainty and time pressure (Sánchez-Zas et al., 2026).

This publication pattern also suggests that adaptive countermeasure selection remains a comparatively under-explored and fragmented topic, whose contributions are often dispersed across journals, workshops, and adjacent application domains rather than consolidated in a single and mature research stream.

A representative cost-aware approach is the stateful Return On Response Investment (RORI)-based methodology proposed by Gonzalez (Gonzalez-Granadillo et al., 2020). Specifically, the authors model countermeasure selection through hypergraphs and use a stateful version of the RORI metric to support the decision process. It is worth noting that this idea is closely aligned with the general need to evaluate defensive actions beyond simple threat mitigation. An earlier conference-stage precursor of this line of work was already presented in Gonzalez Granadillo et al. (2012), which further confirms that cost-aware countermeasure selection has been explored over time through different contributions.

In addition, authors in Li et al. (2020) address the problem from the perspective of multi-path attacks. Their work introduces a dynamic countermeasure selection methodology based on probabilistic attack-response trees, allowing the defender to reason about different attack propagation paths and to select defensive actions accordingly. In particular, the proposed approach shows that countermeasure selection should not be studied only as an isolated reaction to a single threat, but rather as a process influenced by the structure and diversity of attack paths. This perspective also has an antecedent contribution in Li et al. (2018), where the authors already studied the selection of combined countermeasures for multi-attack paths in intrusion response systems.

In addition, Skandylas et al. (2022) investigate security countermeasure selection for component-based software-intensive systems through a model-based perspective. This contribution is especially useful in the present discussion because it shows that countermeasure-selection research is not limited to network-centric intrusion response, but is also being explored in software-architectural settings with different abstraction levels and decision constraints.

Moreover, Kholidy in Kholidy (2021) investigates autonomous mitigation of cyber risks in cyber-physical systems. Concretely, the focus is placed on self-protection mechanisms capable of automatically reducing cyber risk while preserving the operation of the underlying physical environment. Here, it is possible to highlight the increasing importance of adaptive and autonomous reaction in complex infrastructures, where purely manual decision-making may not be fast enough to cope with evolving threats.

Also, authors in Cardellini et al. (2022) propose *IRS-partition*, an IRS based on Deep Q-Networks and system partitions (Phan and Gia Nguyen, 2022). Particularly, the proposal is highly representative of the growing interest in reinforcement learning for reaction. Instead of relying only on static rules or handcrafted optimization functions, the proposed system learns response policies by interacting with the defended environment.

Furthermore, Phan and Bauschert propose *DeepAir* (Phan and Bauschert, 2022), a deep reinforcement learning approach for adaptive intrusion response in Software-Defined Networks. Precisely, their proposal models intrusion response as a Markov decision process and employs a Double Deep Q-Network to derive response policies that aim to maximize attack mitigation while minimizing the impact on benign traffic and deployment cost. A more recent conference-level example of this trend is provided by Reaney et al. (2024), who study network intrusion response through deep reinforcement learning in an aircraft IT-OT scenario. This contribution further confirms the relevance of domain-specific learning-based response policies in safety-critical environments.

More recent application-oriented proposals continue to confirm the diversity of optimization strategies explored in the literature. For example, authors in Hamad et al. (2024) present *REACT*, an autonomous IRS for intelligent vehicles. Such a proposal can be described as interesting since it moves the reaction process directly into the vehicle, reducing the attack window and limiting the dependence on external security operation centers. In addition to defining a comprehensive set of possible responses, the authors also propose a methodology for evaluating and selecting them, supported by dynamic parameter adaptation and an embedded implementation.

Additionally, Bozorgchenani et al. (2024) study intrusion response in 5G and beyond through a joint security vs. QoS optimization approach. Concretely, the presented approach explicitly recognizes that selecting countermeasures in communication infrastructures cannot be reduced to security effectiveness alone, but must also preserve service quality. To address such a trade-off, the authors formulate the problem as a joint optimization task and transform it into a game-theoretical model, deriving theoretical bounds and stable matching-based solutions.

Similarly, Luo (2025) combines improved evolutionary optimization with detection and response mechanisms in fog environments. More specifically, the author proposes an intrusion detection model based on a support vector machine isolation forest together with an intrusion response method that relies on an improved NSGA-II algorithm to select appropriate security decisions. One could say that this proposal illustrates how multi-objective evolutionary optimization can be used to support adaptive reaction in edge and fog infrastructures.

In addition, authors in Caiazza et al. (2026) propose a novel intrusion response methodology based on Timed Competitive Stochastic Games generated from augmented Attack-Defense Trees. Their work is especially relevant because it explicitly incorporates the notion of time into the response process, addressing a limitation of many model-based intrusion response systems that either rely on static attack-response mappings or ignore the duration of attack and defense actions. The authors show both formally and empirically that neglecting time or relying only on immediate-cost decisions may underestimate the total defense cost, and they further report scalability results in terms of planning time and memory usage. This makes the proposal particularly valuable as a model-based and planning-oriented contribution to adaptive cyber reaction.

Bozorgchenani et al. (2026) further investigate countermeasure selection in 5G intrusion response systems through multi-objective optimization and deep Q-learning. This line of work is especially interesting because it combines optimization-based reasoning with reinforcement learning, thus reflecting the growing tendency to explore hybrid intelligent decision strategies for cyber reaction. By focusing on 5G environments, the proposal also reinforces the idea that future intrusion response systems must adapt to complex threat condition and highly dynamic networking scenarios.

Finally, Yue et al. (2025b) propose an intrusion response approach for industrial control systems that combines multi-objective optimization with a Deep Q-Network. In particular, the used approach demonstrates that the reaction is a hybrid decision process in which response quality must be balanced against multiple operational criteria.

These works show that the literature is increasingly moving toward adaptive and intelligent decision strategies, but also that the resulting ecosystem remains highly heterogeneous (Wang et al., 2022). Taken together, these studies demonstrate that countermeasure selection can be formulated through cost-sensitive metrics, probabilistic models, autonomous mitigation strategies, reinforcement learning, and multi-objective optimization (Nespoli et al., 2026). Nevertheless, detailed analyses also reveal a fragmented landscape in which proposals often rely on different abstractions of threats, assets, and countermeasures, as well as different evaluation criteria. Consequently, the field still lacks a sufficiently common basis for describing remediation knowledge and for comparing countermeasure selection strategies in a systematic manner (Boyes and Higgins, 2024), as discussed in the next sections.

2.2. Security standards and structured knowledge for cyber reaction

A relevant aspect when studying the reaction field can be measured as the degree of maturity already reached by the surrounding ecosystem of security standards and structured knowledge resources. Over the years, considerable effort has been devoted to standardizing vulnerabilities, weaknesses, attack knowledge, cyber threat intelligence exchange, configuration assessment, and, more recently, defensive techniques and response orchestration (Taherdoost, 2022; Boyes and Higgins, 2024). Such a trend can be described as important for two main reasons. First, it enables interoperability among tools and organizations. Second, it facilitates the comparison of proposed approaches by grounding them on commonly recognized artifacts and vocabularies (Nespoli et al., 2021b). This trend is also reflected in work on cyber threat intelligence-enabled automated incident response, where structured security knowledge is used to support reaction workflows and attack-handling decisions (Kaiser et al., 2022).

In this sense, Table 1 summarizes the main standards and structured resources that are most relevant to the problem addressed in this work, i.e., the reaction against cyber attacks. Specifically, Table 1 shows a broader perspective that includes several security-related standards (e.g., attack taxonomies, defensive knowledge bases, and advisory formats) with a particular focus on the reaction phase. One can easily say that this broader view is especially useful in such a field since the selection and enforcement of countermeasures depend not only on vulnerability information, but also on platform descriptions, attack knowledge, mitigation guidance, and machine-readable operational artifacts.

Looking at Table 1, a clear asymmetry emerges in the current security standardization landscape. On the one hand, the cybersecurity ecosystem already provides mature and widely adopted resources for describing vulnerabilities, weaknesses, attack knowledge, affected platforms, cyber threat intelligence, and even defensive techniques and response orchestration. On the other hand, the explicit representation of countermeasures as machine-readable objects remains comparatively underdeveloped. One can easily spot that this limitation is not merely a modeling detail. Instead, it has direct practical consequences, since the absence of a rich and interoperable countermeasure model hinders the systematic reuse of remediation knowledge, restricts automation in reaction workflows, and complicates the reproducible comparison of alternative response strategies. Previous work had already identified this gap and showed that the closest remediation-oriented initiatives were not sufficient to support richer automated reaction processes (Nespoli et al., 2021b). The updated landscape reviewed in this article confirms that, despite progress in adjacent areas, this limitation still persists. Therefore, a dedicated model for countermeasures remains necessary, one capable of representing not only their existence, but also their effectiveness, impact, cost, enforcement procedure, and contextual relations to other security knowledge artifacts.

2.3. Adaptive optimization and research gap

The literature reviewed so far confirms that adaptive optimization is already well represented in cyber reaction. Therefore, the main research gap is not the absence of optimization mechanisms, but the absence of a common formulation that allows those mechanisms to be compared and grounded on explicit remediation knowledge. Existing works typically rely on heterogeneous abstractions of assets, threats, and countermeasures, and they are often validated in isolation or within domain-specific scenarios. Consequently, the field still lacks a unified framework that explicitly models asset–threat–countermeasure relations, supports scalable residual risk computation, and enables systematic comparative evaluation across alternative decision strategies.

At the same time, the reviewed works also reveal an important heterogeneity in the way the problem is modeled. Concretely, some

proposals emphasize the economic dimension of response (Gonzalez-Granadillo et al., 2020), others focus on attack propagation paths (Li et al., 2020), and others study autonomous or learning-based response policies in specific domains such as cyber–physical systems (Kholidy, 2021), software-defined networks (Cardellini et al., 2022; Phan and Bauschert, 2022), intelligent vehicles (Hamad et al., 2024), fog environments (Luo, 2025), industrial control systems (Yue et al., 2025b), and 5G infrastructures (Bozorgchenani et al., 2026).

Although this diversity is expected in the reaction phase, where countermeasure selection is naturally studied under different operational assumptions and application domains, these approaches often rely on different abstractions of assets, threats, and countermeasures, and they do not always offer an explicit and semantically rich representation of remediation objects. As a result, the field still lacks a sufficiently common basis for comparing methods and for integrating remediation knowledge into the decision process in a systematic way.

Table 2 provides a qualitative positioning of the main works discussed in Section 2.1 with respect to the approach developed in this article. The comparison focuses on broad dimensions that are especially relevant to adaptive reaction, including the explicit modeling of assets, threats, and countermeasures, the use of structured remediation knowledge, the consideration of effectiveness, cost, and impact, the adoption of adaptive optimization mechanisms, and the scope of the experimental assessment.

The comparison suggests that the main gap is not the absence of optimization-oriented approaches for cyber reaction, since many such approaches already exist. Instead, it is possible to observe a lack of a unified framework that combines four elements at once. First, countermeasures should be modeled as explicit and semantically rich objects instead of implicit actions or domain-specific responses. Second, the decision process should rely on an explicit representation of the relations among assets, threats, and countermeasures, so that the effect of a selected response can be evaluated in a systematic way. Third, the resulting formulation should remain scalable enough to support larger countermeasure spaces and broader comparative experimentation. Fourth, the empirical assessment should not be limited to the validation of a single method in isolation, but should include a wider comparison with improved variants and baseline strategies under a common perspective.

In this scenario, the present article builds on the previously developed research line while addressing the identified gaps through two main contributions:

- It preserves the earlier foundations on structured countermeasure representation, adaptive selection, and parameter calibration, but extends them through an explicit asset–threat–countermeasure formulation and a revised residual risk computation scheme.
- It broadens the empirical validation of the framework through an extended comparative evaluation of alternative decision strategies under a common experimental setting.

3. Theoretical foundations

This section summarizes the main conceptual foundations inherited from the previous research line on adaptive countermeasure selection. Its purpose is to provide the background required to understand the modeling and comparative perspective introduced later in this article. In particular, the framework relies on three closely related pillars, i.e., (i) a structured representation of countermeasures (Section 3.1), (ii) an AIS-based methodology for adaptive countermeasure selection (Sections 3.2, 3.4, 3.3), and (iii) a GA-based calibration stage for tuning key AIS parameters (Section 3.5) (Nespoli et al., 2021b,c,a).

It is important to highlight that this section does not introduce the main contribution of the present article. Instead, it revisits the inherited foundations required to understand the reformulated modeling perspective developed in Section 4.

Table 1

Landscape of security standards and structured knowledge resources relevant to the reaction ecosystem. It is worth noticing that, for the remediation representation, the corresponding standards (i.e., CRE and ERI) have been discontinued, leaving a considerable gap in the field.

Layer	Standard	Maintainer	Current status	Relevance to this work
Vulnerability identification	CVE	MITRE	Active	Canonical identifier for publicly disclosed vulnerabilities; essential to link countermeasures with known vulnerabilities
Vulnerability scoring	CVSS v4.0	FIRST + NVD	Active	Severity scoring reference used to characterize threat criticality and support prioritization
Weakness taxonomy	CWE	MITRE	Active	Useful to connect countermeasures to vulnerabilities and weakness classes
Attack patterns	CAPEC	MITRE	Active	Provides structured attack-pattern knowledge that can support the linkage between threats and reactive measures
Adversary behavior	ATT&CK	MITRE	Active	Valuable for mapping countermeasures to tactics and techniques beyond isolated attack instances
Defensive knowledge graph	MITRE D3FEND	MITRE	Active	Knowledge graph of defensive cybersecurity techniques and countermeasures, highly relevant as structured defensive knowledge complementary to countermeasure modeling and reaction workflows
Platform identification	CPE	NIST + NVD	Active	Standard naming scheme for software, operating systems, and hardware platforms, useful to define the applicability of countermeasures
Configuration issues	CCE	NIST	Active	Enables correlation of security configuration issues and supports links between countermeasures and configuration knowledge
Assessment + Compliance	OVAL, XCCDF, OCIL	NIST + SCAP	Active	Relevant for automated assessment, checklist definition, and compliance evaluation around preventive countermeasures
Software inventory	SWID	ISO/IEC 19770-2	Active	Useful for software identification, inventory, and patch-related automation.
Threat intelligence representation	STIX 2.1	OASIS	Active	Standard language for structured cyber threat intelligence, convenient for integrating threat context with reaction workflows
Threat intelligence transport	TAXII 2.1	OASIS	Active	Standard transport/API layer for exchanging CTI, especially STIX-based intelligence
Security advisories	CSAF 2.0	OASIS	Active	Structured advisory format covering products, vulnerabilities, impact, and remediation, effectively the modern evolution beyond CVRF
Response actuation	OpenC2	OASIS	Active	Standard language for machine-to-machine command and control of cyber defense components, highly appropriate for countermeasure enforcement
Response orchestration	CACAO 2.0	OASIS	Active	Standardized representation of cybersecurity playbooks and courses of action, helpful for operationalizing reaction workflows
Malware characterization	MAEC	MITRE community	Active	Structured malware description format; useful as complementary context in malware-centric scenarios
Remediation representation	CRE+ERI	NIST + SCAP (historical)	Discontinued	Historically the closest attempt to remediation standardization, but insufficient and no longer maintained

An abstract view of the integrated framework is proposed in Fig. 1, which summarizes the relation between the standardized countermeasure representation, the AIS-based countermeasure selector, and the GA-based parameter calibration layer.

3.1. Countermeasure standard representation

A first requirement for an adaptive reaction strategy is the existence of a machine-readable representation of countermeasures. Without a structured description of remediation objects, it is difficult to build reusable knowledge bases, compare response strategies consistently, or automate the selection of defensive actions. For this reason, the proposed framework relies on a standardized countermeasure model originally proposed as a step toward the pre-standardization of remediation knowledge, as firstly discussed in Nespoli et al. (2021b).

Let cm denote a generic countermeasure. Its representation is defined as:

$$cm_{ID} = \left(\underbrace{ID, Eff, Imp, Cost, X_c, X_p, X_v, X_a, \phi}_{\text{mandatory}}, \underbrace{P, \delta}_{\text{optional}} \right) \quad (1)$$

where ID is the identifier of the countermeasure, Eff denotes its effectiveness, Imp its impact, and $Cost$ its cost. Then, the terms X_c , X_p , X_v , and X_a provide links to external security knowledge bases, such as configurations, platforms, vulnerabilities, and attacks, respectively, while ϕ describes the enforcement procedure in a machine-readable form. Last but not least, the optional fields P and δ capture additional parameters and metadata.

Table 2

Qualitative positioning of representative countermeasure selection approaches with respect to the dimensions most relevant to this study. It is worth noticing that ATCM refers to Asset–Threat–Countermeasure Model. The assignment of these symbols is intended as a high-level qualitative interpretation of the main emphasis of each work rather than as a strict binary judgment.

Work	Main domain	Explicit ATCM	Structured CM representation	Multi-criteria response	Adaptive optimization	Extended comparative evaluation
Gonzalez-Granadillo et al. (2020)	General reaction	≈	✗	✓	≈	✗
Li et al. (2020)	Multi-path attacks	≈	✗	≈	≈	✗
Kholidy (2021)	Cyber–physical systems	✗	✗	≈	✓	✗
Cardellini et al. (2022)	Partition-based intrusion response	✗	✗	≈	✓	✗
Hamad et al. (2024)	Intelligent vehicles	≈	✗	≈	✓	✗
Bo-zorgchenani et al. (2024)	5G and beyond	✗	✗	✓	✓	✗
Luo (2025)	Fog environments	✗	✗	✓	✓	✗
Bo-zorgchenani et al. (2026)	5G intrusion response	✗	✗	✓	✓	✗
Phan and Bauschert (2022)	Software-Defined Networks	✗	✗	✓	✓	✗
Yue et al. (2025b)	Industrial control systems	≈	✗	✓	✓	✗
Caiazza et al. (2026)	General cyber reaction	≈	✗	✓	✓	≈
This work	General reaction	✓	✓	✓	✓	✓

✓ Yes – ✗ No – ≈ Partially

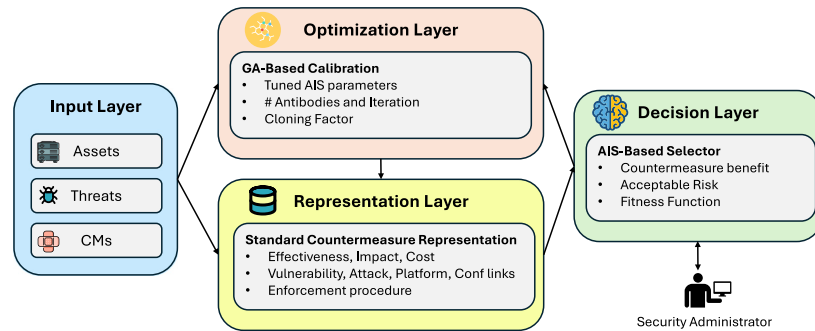


Fig. 1. Inherited conceptual foundations of the research line. The figure summarizes the relation between the standardized countermeasure representation, the AIS-based countermeasure selector, and the GA-based parameter-calibration layer developed in previous work, which together provide the conceptual basis for the modeling and comparative perspective adopted in this article.

Thus, the presented representation can be described as consistent within the reaction ecosystem because it provides a consistent semantic basis for describing remediation actions beyond simple textual descriptions. In addition, it enables the later decision layer to reason quantitatively about effectiveness, impact, and cost. Also, the model incorporates the notion of countermeasure maturity, which reflects the historical success or failure of previous deployments and can therefore be exploited by adaptive reaction mechanisms (Nespoli et al., 2021b).

3.2. AIS-based countermeasure-selection foundations

Building on the standardized countermeasure representation, the second pillar of the proposed framework is an AIS-based methodology for selecting the optimal set of atomic countermeasures. The main

rationale of this approach is to translate the countermeasure selection problem into an immunological ecosystem, thereby exploiting the adaptive and evolutionary properties of AIS (Nespoli et al., 2021c).

Let

$$A = \{A_1, A_2, \dots, A_{N_A}\} \quad (2)$$

be the set of assets composing the protected system. Each asset A_x is associated with a criticality value $CR(A_x) \in [0, 1]$, expressing its relative importance within the system. Realistically, assets may expose vulnerabilities and may also be affected by ongoing attacks. Thus, let V be the set of vulnerabilities present in the system and T the set of attacks currently affecting it. Then, the global threat set τ is:

$$\tau = T \cup V \quad (3)$$

Within the AIS formulation, these threats act as *antigens*. In turn, the available atomic countermeasures

$$CM = \{cm_1, cm_2, \dots, cm_N\} \quad (4)$$

are combined into candidate solutions that play the role of *antibodies*. The reaction process is therefore modeled as an adaptive search for the set of countermeasures (i.e., the antibodies) that best protects the affected assets under the current threat conditions (i.e., the antigens).

One could easily spot that this translation is especially suitable because AIS exhibits desirable properties for reaction, including diversification, specificity, self-regulation, and memorization. As a result, the methodology is not restricted to a fixed mapping between threats and responses, but is able to iteratively explore and refine alternative remediation sets (Nespoli et al., 2021c).

An important aspect of this formulation is that the response is not limited to the selection of a single countermeasure. In realistic scenarios, it is possible that several atomic countermeasures may be jointly applied to the same asset, and their overall effect must therefore be evaluated as a combined defensive action. For this reason, the framework reasons about the aggregated benefit of countermeasure sets. This idea is fundamental because the later computation of residual risk depends on the protection level provided by the selected set of countermeasures over each asset, rather than on isolated remediation actions only.

3.3. Countermeasure benefit, acceptable risk, and fitness

Once the immunological modeling has been established, the next step is to define the quantitative criteria guiding the adaptive selection of countermeasures. As previously said, the framework must evaluate both the benefit of individual atomic countermeasures and the aggregated benefit of multiple countermeasures applied to the same asset. Here, a fundamental concept is the *countermeasure benefit*, which balances the effectiveness of a remediation against its potential negative impact on the system and cost (e.g., implementation, maintenance, indirect, etc.). For a given atomic countermeasure cm_i , the benefit $B(cm_i)$ is defined as:

$$B(cm_i) = \omega \times (Ef f(cm_i))^{1 - \left(\frac{Imp(cm_i) + Cost(cm_i)}{2} \right)} \quad (5)$$

where ω is a scaling factor that maps the resulting value to the interval $[1, 10]$. This formulation is intended to reward countermeasures that remain highly effective while penalizing those whose operational impact and cost are high. In this way, the benefit term does not reflect effectiveness alone, but the balance between defensive gain and deployment burden.

Next, the second key concept is the use of *acceptable risk*. Instead of minimizing risk blindly, the methodology seeks to adjust the residual risk of each asset to a level consistent with its importance (i.e., its criticality). For an asset A_x threatened by τ_k and protected by a candidate countermeasure set $CM_j(A_x)$, the risk level is defined as:

$$RL(\tau_k, A_x, CM_j(A_x)) = \frac{P(\tau_k, A_x) \times I(\tau_k) \times CR(A_x)}{B(CM_j(A_x))} \quad (6)$$

where $P(\tau_k, A_x)$ is the probability of occurrence of the threat over the asset, $I(\tau_k)$ is the threat impact, and $CR(A_x)$ is the asset criticality.

The acceptable risk associated with each asset is computed as:

$$RL_f(A_x) = \alpha \times (1 - CR(A_x)) \quad (7)$$

with $\alpha = 10$. The constant $\alpha = 10$ is used as a normalization factor so that the acceptable risk scale remains aligned with the benefit scale adopted in Eq. (5), where ω maps countermeasure benefit to the interval $[1, 10]$. Under this choice, assets with higher criticality are assigned lower acceptable-risk thresholds, while less critical assets tolerate proportionally higher residual risk on the same numerical scale. Therefore, α should be understood as a design choice for scale consistency rather

than as a domain-dependent constant. Based on these definitions, the AIS seeks to minimize the following fitness function:

$$\min_{CM_j(A_x)} f = \left| RL(\tau_k, A_x, CM_j(A_x)) - RL_f(A_x) \right| \quad (8)$$

This criterion is one of the distinctive aspects of the framework, because it explicitly avoids both overprotection and under-protection. The best solution is not necessarily the one that minimizes risk at any cost, but the one that best adjusts the protection level of the asset to its acceptable risk threshold.

3.4. AIS-powered reaction

The previous modeling is implemented through an AIS-powered reaction process in which candidate antibodies are iteratively improved until a satisfactory solution is found. From an abstract viewpoint, the methodology follows the traditional AIS logic, i.e., an initial population of antibodies is generated, their affinity is evaluated through the fitness function, the best antibodies are cloned, mutated, and compared against the current population, and low-affinity solutions are progressively discarded (Fernandes et al., 2017).

The framework considers two main reaction modes. In the *static* mode, vulnerabilities act as antigens and the methodology is used in a preventive manner, for example, after the detection of weaknesses by vulnerability scanners. In the *dynamic* mode, ongoing attacks act as antigens and the methodology is applied in a reactive fashion, typically after security monitoring components such as IDSs have reported malicious activity. In both cases, the goal is to determine the most appropriate set of atomic countermeasures for the affected assets, although the timing requirements and operational context differ significantly.

Another important aspect of the methodology is that it naturally supports semi-automatic decision making. In fact, the final antibody selected by the AIS can be presented to the security administrator, who may decide whether to enforce the proposed countermeasures as suggested or whether to adapt the final response. Such an interesting feature is especially relevant in practical settings, where reaction often combines algorithmic support with human supervision.

3.5. GA-based parameter calibration

Although the AIS-powered selector provides an adaptive mechanism for countermeasure selection, its behavior depends on several input parameters that influence both the quality of the obtained solution and the corresponding execution time. In order to reduce the subjectivity associated with manually chosen values, the framework was extended through AISGA, a GA-based calibration stage (Nespoli et al., 2021a).

In this proposal, each GA individual represents a specific configuration of the AIS methodology. The calibration focuses on the following parameters:

$$P_i \in \{Iter, N_{ab}, K, N_{cm}\} \quad (9)$$

where *Iter* is the number of AIS iterations, N_{ab} is the number of antibodies, K is the cloning factor, and N_{cm} is the number of atomic countermeasures available to the selector.

The goal of AISGA is to identify suitable ranges for those parameters by solving a multi-objective optimization problem that jointly considers the fitness achieved by the AIS selector and its execution time:

$$\min g = f(CM_i) + \log_{10} T \quad (10)$$

where $f(CM_i)$ is the fitness of the best antibody returned by the AIS and T is the execution time.

From this perspective, AISGA should be understood as a complementary calibration layer rather than as a replacement for the AIS-based selector. Specifically, the semantic basis of the framework is still provided by the standardized countermeasure model, and the

Table 3

Main notation used throughout the paper.

Symbol	Meaning
A	Set of assets in the protected system/infrastructure
T	Set of attacks or threats affecting the system
V	Set of vulnerabilities present in the system
τ	Global threat set, defined as $\tau = T \cup V$
CM	Set of available atomic countermeasures
cm_i	Generic atomic countermeasure
$CR(A_x)$	Criticality of asset A_x/a_i
$Eff(cm)$	Effectiveness of a countermeasure
$Imp(cm)$	Operational impact of a countermeasure/impact of threat t_j
$Cost(cm)$	Cost of a countermeasure
$B(cm_i)$	Benefit of atomic countermeasure cm_i
$RL(\tau_k, A_x, CM_j(A_x))$	Risk level of asset A_x under threat τ_k and candidate protection set $CM_j(A_x)$
$RL_f(A_x)$	Acceptable risk threshold associated with asset A_x
S	Candidate solution, represented as a subset of selected countermeasures
$Risk(S)$	Baseline residual risk of candidate solution S
$Risk_{op}(S, \pi)$	Extended operational objective under operational profile π
π	Operational profile, defined by budget, prerequisites, exclusions, and synergies
M	Binary asset-countermeasure coverage matrix
ω	Scaling factor used in the countermeasure-benefit formulation
α	Scaling factor used in the acceptable-risk formulation
$\lambda_{pre}, \lambda_{exc}$	Penalty coefficients for prerequisite and exclusion violations

actual reaction is still driven by the AIS formulation grounded on countermeasure benefit and acceptable risk. AISGA is able to add a higher-level optimization stage that improves the robustness of the framework by stabilizing its most influential input parameters.

Overall, the elements summarized in this section define the inherited conceptual basis of the research line. Nevertheless, they do not represent by themselves the main contribution of the present article. As discussed in Section 2, the broader gap addressed here concerns the need for a more explicit asset-threat-countermeasure formulation and for a comparative evaluation framework that supports the systematic assessment of alternative decision strategies. These aspects are introduced in the next section.

4. Proposed approach

While Section 3 summarized the inherited foundations of the research line, the present section introduces the main modeling contribution of this article. The goal is to move from the earlier selector-oriented view toward an explicit and scalable formulation in which assets, threats, and countermeasures are modeled as first-class entities. That is, this reformulation provides a clearer basis for evaluating candidate solutions, computing residual risk, and comparing alternative decision strategies under a unified perspective.

In the following, Section 4.1 describes the domain entities and their relations, focusing on the explicit representation of assets, threats, and countermeasures. Then, Section 4.2 formalizes the residual risk computation used to evaluate candidate solutions, while Section 4.3 presents the extended problem formulation. Next, Section 4.4 introduces the coverage representation that supports the efficient modeling of the relations between assets and countermeasures. Finally, Section 4.5 discusses the main computational design choices adopted to improve scalability and make the formulation practical for larger countermeasure spaces.

To improve readability, Table 3 summarizes the main symbols used throughout the remainder of the paper. In particular, it collects the notation associated with the inherited AIS-based formulation introduced in Section 3 and the explicit asset-threat-countermeasure model presented in Section 4, so that the mathematical definitions can be followed more easily.

4.1. Domain modeling

The protected environment is modeled through three main entity types, i.e., assets, threats, and countermeasures. Let:

$$A = \{a_1, a_2, \dots, a_{N_A}\} \quad (11)$$

be the set of assets composing the protected infrastructure. Each asset $a_i \in A$ is associated with a criticality value:

$$crit(a_i) \in [0, 1] \quad (12)$$

that expresses its relative importance within the system.

Let:

$$T = \{t_1, t_2, \dots, t_{N_T}\} \quad (13)$$

be the set of threats affecting the infrastructure. Each threat $t_j \in T$ is characterized by an occurrence probability:

$$prob(t_j) \in [0, 1] \quad (14)$$

and an impact value:

$$imp(t_j) \in [0, 1] \quad (15)$$

Finally, let:

$$CM = \{cm_1, cm_2, \dots, cm_{N_{CM}}\} \quad (16)$$

be the set of available countermeasures. Each countermeasure $cm_k \in CM$ is associated with a cost:

$$cost(cm_k) \in \mathbb{R}^+ \quad (17)$$

and an effectiveness value:

$$eff(cm_k) \in [0, 1] \quad (18)$$

It is important to remark that the main aspect of the proposed formulation is that the relations among these entities are modeled explicitly. In fact, countermeasures and assets are connected through a many-to-many relation, since a countermeasure may protect several assets and an asset may be covered by multiple countermeasures. Similarly, threats and assets are also related in a many-to-many way, since a threat may affect several assets and an asset may be exposed to multiple threats. Therefore, for each asset a_i the framework considers:

$$T(a_i) \subseteq T \quad (19)$$

as the set of threats that may affect it, and:

$$CM(a_i) \subseteq CM \quad (20)$$

as the set of countermeasures that can protect it.

Under this perspective, a candidate solution is defined as a subset of countermeasures:

$$S \subseteq CM \quad (21)$$

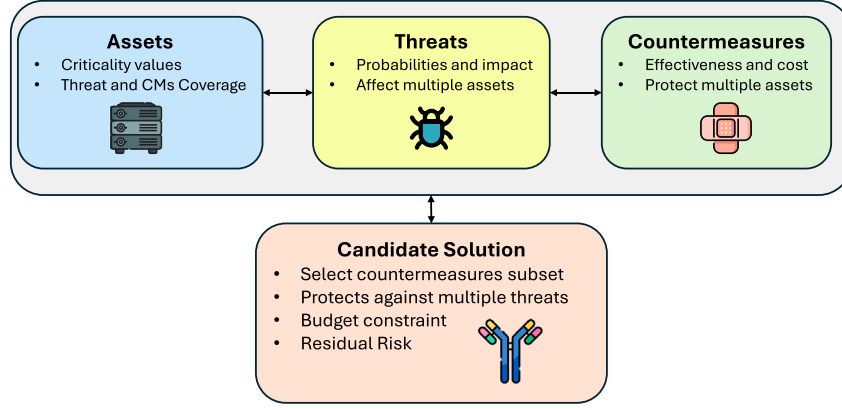


Fig. 2. Proposed modeling and problem formulation adopted in this work. In contrast to Fig. 1, which summarizes the inherited selector-oriented framework, this figure represents the main modeling novelty of the article: an explicit asset–threat–countermeasure formulation in which candidate countermeasure sets are evaluated through residual risk under budget constraints.

such that the total cost of the selected countermeasures respects the available budget:

$$\sum_{cm \in S} cost(cm) \leq B \quad (22)$$

Thus, such explicit asset–threat–countermeasure modeling step provides a more direct and comprehensive representation of the reaction problem than the earlier selector-oriented view alone. In particular, it makes it possible to reason about the coverage provided by the selected countermeasure set over the assets of the infrastructure and, consequently, to compute the remaining risk in a principled way.

Fig. 2 summarizes the explicit asset–threat–countermeasure formulation adopted in this work and the role of the candidate solution in the computation of residual risk under budget constraints. Unlike Fig. 1, which summarizes the inherited conceptual foundations of the previous research line (i.e., standardized countermeasure representation, AIS-based selection, and GA-based parameter calibration), Fig. 2 highlights the main modeling novelty introduced in this article. More specifically, the new figure moves from the earlier selector-oriented perspective toward an explicit asset–threat–countermeasure formulation in which assets, threats, and countermeasures are modeled as first-class entities, candidate solutions are represented as subsets of countermeasures under budget constraints, and their quality is evaluated through residual risk computation. In this sense, Fig. 2 visualizes the reformulated problem representation that enables clearer reasoning about coverage, more principled residual risk evaluation, and a more scalable basis for comparative experimentation.

4.2. Residual risk formulation

Based on the previous asset–threat–countermeasure model, the effect of a candidate solution S is evaluated through the residual risk that remains over the protected infrastructure after the selected countermeasures have been applied. The formulation adopted in this work assumes that each countermeasure covering an asset reduces the effect of the threats affecting that asset according to its effectiveness. Therefore, the residual multiplicative factor associated with the selected protection on a given asset is computed as:

$$\prod_{\substack{cm \in S \\ cm \in CM(a_i)}} (1 - eff(cm)) \quad (23)$$

Using this term, the residual risk of a solution S is defined as:

$$Risk(S) = \sum_{a_i \in A} \left[crit(a_i) \sum_{t_j \in T(a_i)} \left(prob(t_j) \times imp(t_j) \times \prod_{\substack{cm \in S \\ cm \in CM(a_i)}} (1 - eff(cm)) \right) \right] \quad (24)$$

The multiplicative term models the cumulative attenuation produced by the selected countermeasures covering a given asset. Under this interpretation, each additional countermeasure reduces the remaining exposure of the asset, so that the residual risk reflects both threat severity and the aggregated protection provided by the selected portfolio. This formulation presents several advantages. First, it preserves the intuition that highly critical assets should contribute more strongly to the global residual risk. Second, it accounts for both the probability and the impact of the threats affecting each asset. Third, it captures the cumulative protective effect of multiple countermeasures applied over the same asset. In this sense, the residual risk formulation naturally supports the selection of countermeasure sets rather than isolated actions.

By doing this, the resulting optimization problem can therefore be expressed as:

$$\min_{S \subseteq CM} Risk(S) \quad (25)$$

subject to the budget constraint in Eq. (22).

Although this objective differs from the acceptable risk-based fitness function summarized in Section 3, both views are conceptually aligned. In fact, the original formulation emphasized the adjustment of each asset to its acceptable protection level, whereas the present one makes the residual risk structure of the problem more explicit and more directly usable in a broader comparative evaluation.

The formulation above defines the baseline countermeasure selection problem considered in this article. In what follows, this formulation will be referred to as the baseline residual risk model, since it evaluates candidate countermeasure sets exclusively through residual risk under a budget constraint. In particular, one can say that such a baseline view is useful because it provides a clean and interpretable optimization objective, and it serves as the reference problem for the first part of the experimental evaluation.

4.3. Extended operational formulation under deployment constraints

While the baseline formulation introduced above provides a clean reference model for countermeasure selection, real operational environments often impose additional restrictions that cannot be represented through residual risk and budget alone. Concretely, some countermeasures may imply dependencies (e.g., require the prior deployment of others, some combinations may be incompatible, and some defensive actions may produce beneficial interaction effects when jointly selected). For this reason, the experimental study also considers an extended operational formulation in which the baseline residual risk model is enriched with deployment dependencies and interaction effects.

Let π denote an operational profile associated with a given experimental instance. Each profile π is defined as:

$$\pi = (B_\pi, \mathcal{P}_\pi, \mathcal{E}_\pi, \mathcal{Y}_\pi) \quad (26)$$

where B_π is the budget available under that profile, $\mathcal{P}_\pi$ is the set of prerequisite relations, $\mathcal{E}_\pi$ is the set of mutual-exclusion relations, and $\mathcal{Y}_\pi$ is the set of synergistic countermeasure pairs.

A prerequisite relation is represented as an ordered pair $(cm_i, cm_j) \in \mathcal{P}_\pi$, meaning that countermeasure cm_j should only be deployed if countermeasure cm_i is also selected. Accordingly, the number of violated prerequisites in a candidate solution S is defined as:

$$V_{\text{pre}}(S, \pi) = \sum_{(cm_i, cm_j) \in \mathcal{P}_\pi} \mathbf{1}[cm_j \in S \wedge cm_i \notin S] \quad (27)$$

Similarly, a mutual-exclusion relation is represented as an unordered pair $\{cm_i, cm_j\} \in \mathcal{E}_\pi$, meaning that both countermeasures should not be selected simultaneously. The number of exclusion violations in a candidate solution S is therefore:

$$V_{\text{exc}}(S, \pi) = \sum_{\{cm_i, cm_j\} \in \mathcal{E}_\pi} \mathbf{1}[cm_i \in S \wedge cm_j \in S] \quad (28)$$

In addition, some countermeasure pairs may generate beneficial interaction effects when jointly deployed. Let $\mathcal{Y}_\pi$ denote the set of synergistic pairs under profile π . For each $\{cm_i, cm_j\} \in \mathcal{Y}_\pi$, a multiplicative factor $\gamma_{ij} \in (0, 1]$ is associated with the pair, so that values below 1 represent an additional reduction of the residual risk when both the countermeasures are selected together. The cumulative synergy factor of a candidate solution S under profile π is defined as:

$$\Gamma(S, \pi) = \prod_{\substack{\{cm_i, cm_j\} \in \mathcal{Y}_\pi \\ cm_i \in S, cm_j \in S}} \gamma_{ij} \quad (29)$$

with the convention that $\Gamma(S, \pi) = 1$ when no synergistic pair is activated.

Based on the previous components, the extended operational objective considered under profile π is defined as:

$$Risk_{\text{op}}(S, \pi) = \Gamma(S, \pi) Risk(S) + \lambda_{\text{pre}} V_{\text{pre}}(S, \pi) + \lambda_{\text{exc}} V_{\text{exc}}(S, \pi) \quad (30)$$

where $\lambda_{\text{pre}} > 0$ and $\lambda_{\text{exc}} > 0$ are penalty coefficients controlling the severity of prerequisite and exclusion violations, respectively. In this way, the baseline residual risk is preserved as the core objective, while deployment dependencies and beneficial interactions are incorporated into the evaluation of candidate solutions.

The corresponding extended optimization problem is therefore:

$$\min_{S \subseteq CM} Risk_{\text{op}}(S, \pi) \quad (31)$$

subject to:

$$\sum_{cm \in S} cost(cm) \leq B_\pi \quad (32)$$

Thus, unlike the baseline formulation, the extended operational formulation explicitly models the fact that countermeasure quality depends on the isolated protective effect of each selected action and, also, on deployability, compatibility, and interaction structure. In the constrained experiments reported later in this article, the penalty coefficients are instantiated as $\lambda_{\text{pre}} = 7.0$ and $\lambda_{\text{exc}} = 4.0$, in accordance with the operational profiles considered in the constrained evaluation.

It is important to clarify that each of the operational profiles used in the experimental evaluation denotes a parametric profile family rather than a single fixed configuration. For every run, the corresponding profile family is instantiated by randomly sampling its budget cap B_π , prerequisite relations $\mathcal{P}_\pi$, exclusion relations $\mathcal{E}_\pi$, and synergistic pairs $\mathcal{Y}_\pi$ using that run's own random seed. Consequently, across independent runs, no two runs are evaluated under an identical operational profile instance, even when nominally drawn from the same family.

4.4. Coverage representation

To support efficient evaluation of candidate solutions, the relation between assets and countermeasures is represented through a binary coverage matrix:

$$M \in \{0, 1\}^{N_A \times N_{CM}} \quad (33)$$

where

$$M_{i,k} = \begin{cases} 1, & \text{if } cm_k \text{ covers } a_i \\ 0, & \text{otherwise.} \end{cases} \quad (34)$$

It is easy to spot that this representation makes it possible to identify, for each candidate solution, which assets are actually affected by the selected countermeasures and to compute their aggregated protection more efficiently. In particular, if a new countermeasure is added to a partial solution, only the assets covered by that countermeasure need to update their residual multiplicative factor. This observation is central to the scalable evaluation scheme adopted in the implementation.

Also, the explicit coverage structure makes the problem more transparent from a modeling standpoint. Rather than assuming an implicit or abstract relation between response actions and protected objects, the framework states directly which defensive actions apply to which assets, thereby enabling both better interpretability and more efficient computation.

4.5. Computational design and scalability considerations

A practical difficulty of the previous optimization objective is that residual risk computation can become expensive when the number of assets and, especially, candidate countermeasures grows. For this reason, the formulation is accompanied by a computational design intended to support larger search spaces.

First, the residual risk evaluation is organized around vectorized operations over the coverage structure, thereby avoiding unnecessary inner loops in the critical parts of the computation. Second, the evaluation can reuse partial results through incremental caching. More specifically, when a new countermeasure is added to a candidate solution, the residual contribution only needs to be updated for the assets covered by that countermeasure, instead of reevaluating the whole infrastructure from scratch. Third, for very large instances, the framework can combine this evaluation scheme with candidate-sampling strategies in order to keep the computational burden within practical limits during search.

These design choices do not change the semantic meaning of the model. Nevertheless, they strongly affect its operational viability. In this sense, the contribution of the present formulation is twofold, i.e., (i) it provides a more explicit problem representation and, at the same time, (ii) a more scalable basis for evaluating candidate countermeasure sets in large experimental scenarios.

4.6. Hybrid AIS-GA procedure under operational constraints

To explicitly detail the search dynamics and clarify the treatment of operational constraints, Algorithm 1 presents the complete execution flow of the Hybrid AIS-GA strategy. The algorithm is designed to navigate the combinatorial space of countermeasures by alternating between the hyper-mutational exploitation of an AIS and the evolutionary exploration of a GA.

The procedure relies on a binary encoding, where each candidate solution is represented as a vector $x \in \{0, 1\}^m$. A value of $x_i = 1$ indicates that countermeasure c_i is selected for deployment, while $x_i = 0$ means it is discarded. The optimization process begins with an Initialization phase, where a population Π of $N = 50$ random binary vectors is generated. To ensure mathematical consistency with the extended operational formulation (Section 4.3), every newly generated individual immediately undergoes a REPAIRBUDGET operation. This

function treats the available financial budget B as a hard constraint (satisfying Eq. (32)). If a candidate solution exceeds the budget, the repair heuristic iteratively removes the selected countermeasure with the lowest marginal benefit-per-cost ratio until the portfolio becomes economically feasible.

The core of the algorithm resides in the Evolution with AIS/GA phase switching block. To leverage the strengths of both metaheuristics, the search alternates between two distinct operational modes every $\tau = 10$ generations. This cyclic alternation is governed by the deterministic condition $[(g-1)/\tau] \bmod 2 = 0$, where g is the current generation index up to $G_{\max} = 200$.

During the AIS (clonal) phase, the algorithm focuses on local exploitation and diversification. The most promising candidate solutions (the elite set Π_e) are selected and cloned $N_{\text{clones}} = 20$ times each. These clones are then subjected to a hypermutation operator. In this step, the mutation rate p_{mut} is not fixed; rather, it is inversely proportional to the affinity (i.e., the fitness) of the parent antibody. Highly fit solutions undergo minor refinements to preserve their quality, while lower-quality solutions experience aggressive mutation to escape local optima.

Conversely, during the GA phase, the algorithm prioritizes global exploration and information sharing. The population is regenerated through standard genetic operators. Parents are chosen via binary tournament selection, ensuring that fitter individuals have a higher probability of reproduction. The selected pairs undergo uniform crossover with a probability $p_c = 0.8$ to combine advantageous countermeasure blocks, followed by a standard bit-flip mutation with a fixed, low probability $\mu = 0.05$ to maintain genetic diversity. Importantly, any new offspring generated in either phase is subsequently passed through the REPAIRBUDGET function to guarantee financial feasibility.

A critical aspect of the proposed algorithm is the handling of the extended operational constraints, specifically prerequisite relations ($\mathcal{P}$) and mutual exclusions ($\mathcal{E}$). Unlike the budget restriction, which is enforced via hard repair, topological dependencies are handled through a soft-penalty approach integrated directly into the EVALUATE function. For every evaluated solution x , the algorithm computes the baseline residual risk (r_{base}) and applies the cumulative synergy factor (Γ) if complementary countermeasures are co-selected. Then, it counts the exact number of prerequisite violations (v_p) and mutual-exclusion conflicts (v_E).

The final fitness value f is computed by penalizing the synergistic residual risk using the coefficients $\lambda_P = 7.0$ and $\lambda_E = 4.0$. This design directly implements the $Risk_{op}$ objective formalized in Eq. (30). By penalizing rather than rigidly repairing these topological dependencies, the evolutionary process maintains a smoother fitness landscape. It allows the algorithm to temporarily traverse operationally invalid states (e.g., selecting a tool without its prerequisite) if those states serve as stepping stones toward highly optimal, fully compliant portfolios in subsequent generations. The algorithm terminates after $G_{\max}$ iterations, returning x^* , the countermeasure set that minimizes the penalized operational risk.

5. Experimental analysis

5.1. Objectives of the experimental study

The goal of the extended evaluation is to verify the feasibility of the proposed framework and to better understand its behavior when compared against stronger alternatives. The experimental analysis considers the proposed framework together with a set of foundational paradigms and comparison strategies.

The extended evaluation is conducted over a collection of experimental instances designed to represent different reaction scenarios. Generally, each instance is defined by a set of protected assets, a set of threats affecting those assets, and a pool of available countermeasures that can be selected by the compared methods. In this way, the

Algorithm 1: Hybrid AIS-GA for Operationally Constrained Countermeasure Selection

Input: Assets A , threats T , candidate countermeasures $C = \{c_1, \dots, c_m\}$, budget B ;
Prerequisites $\mathcal{P}$, exclusions $\mathcal{E}$, synergies $\mathcal{Y}$;
Population size $N = 50$, max generations $G_{\max} = 200$, phase-switch interval $\tau = 10$;
Elite size $E = 2$, clones per cycle $N_{\text{clones}} = 20$, crossover rate $p_c = 0.8$, mutation rate $\mu = 0.05$;
Penalty weights $\lambda_P = 7.0, \lambda_E = 4.0$.
Output: Best feasible countermeasure set $x^* \in \{0, 1\}^m$

```

1 Encoding: binary vector  $x$ , where  $x_i = 1$  iff countermeasure  $c_i$  is selected.
2 Initialization
3  $\Pi \leftarrow \emptyset$ 
4 for  $i \leftarrow 1$  to  $N$  do
5    $x \leftarrow$  random binary vector of length  $m$ 
6    $x \leftarrow \text{REPAIRBUDGET}(x, B)$  // Enforce hard constraint (Eq. (32))
7    $(f, r) \leftarrow \text{EVALUATE}(x)$ 
8    $\text{add}(x, f, r)$  to  $\Pi$ 
9 Sort  $\Pi$  by ascending  $f$ 
10  $x^* \leftarrow \Pi[1].x$ 
11 Evolution with AIS/GA phase switching
12 for  $g \leftarrow 1$  to  $G_{\max}$  do
13    $\Pi_e \leftarrow$  top- $E$  individuals in  $\Pi$ 
14   if  $[(g-1)/\tau] \bmod 2 = 0$  then
15     // AIS (clonal) phase
16      $\Omega \leftarrow \Pi_e$ 
17     foreach  $u \in \Pi_e$  do
18       for  $k \leftarrow 1$  to  $N_{\text{clones}}$  do
19          $y \leftarrow u.x$ 
20          $p_{\text{mut}} \leftarrow \text{HYPERMUTATIONRATE}(u, \mu)$ 
21          $y \leftarrow \text{BITMUTATION}(y, p_{\text{mut}})$ 
22          $y \leftarrow \text{REPAIRBUDGET}(y, B)$ 
23          $(f_y, r_y) \leftarrow \text{EVALUATE}(y)$ 
24          $\text{add}(y, f_y, r_y)$  to  $\Omega$ 
25    $\Pi \leftarrow$  best  $N$  individuals from  $\Omega$ 
26   else
27     // GA phase
28      $\Omega \leftarrow \Pi_e$ 
29     while  $|\Omega| < N$  do
30        $p_1 \leftarrow \text{TOURNAMENTSELECT}(\Pi), p_2 \leftarrow \text{TOURNAMENTSELECT}(\Pi)$ 
31        $(o_1, o_2) \leftarrow \text{CROSSOVER}(p_1.x, p_2.x, p_c)$ 
32        $o_1 \leftarrow \text{BITMUTATION}(o_1, \mu), o_2 \leftarrow \text{BITMUTATION}(o_2, \mu)$ 
33        $o_1 \leftarrow \text{REPAIRBUDGET}(o_1, B), o_2 \leftarrow \text{REPAIRBUDGET}(o_2, B)$ 
34        $\text{Evaluate } o_1, o_2$  and  $\text{add to } \Omega$  (until size  $N$ )
35    $\Pi \leftarrow \Omega$ 
36   Sort  $\Pi$  by ascending  $f$ 
37   if  $\Pi[1].f < \text{EVALUATE}(x^*).f$  then
38      $x^* \leftarrow \Pi[1].x$ 
39 return  $x^*$ 
40 Function EVALUATE( $x$ )
41    $r_{\text{base}} \leftarrow \text{RESIDUALRISK}(x; A, T, C)$  // Eq. (24)
42    $\Gamma \leftarrow \text{SYNERGYFACTOR}(x, \mathcal{Y})$  // Eq. (29)
43    $v_p \leftarrow \text{PREREQUISITEVIOLATIONS}(x, \mathcal{P})$  // Eq. (27)
44    $v_E \leftarrow \text{EXCLUSIONVIOLATIONS}(x, \mathcal{E})$  // Eq. (28)
45    $f \leftarrow (\Gamma \cdot r_{\text{base}}) + \lambda_P v_p + \lambda_E v_E$  // Eq. (30)
46   return  $(f, r_{\text{base}})$ 
47 Function REPAIRBUDGET( $x, B$ )
48   while  $\text{Cost}(x) > B$  do
49      $\text{Remove selected item } x_i = 1$  with smallest marginal benefit-per-cost
50 return  $x$ 

```

experimental setting remains consistent with the modeling and problem formulation presented in Section 4.

For reproducibility, each synthetic instance was generated according to a fixed protocol. Asset criticalities were sampled from a continuous uniform distribution $U \sim (0.5, 1.0)$, threat occurrence probabilities from a continuous uniform distribution $U \sim (0.3, 0.8)$, and threat impacts from a continuous uniform distribution $U \sim (0.6, 1.0)$. Likewise, countermeasure costs and effectiveness values were generated from a uniform distribution $U \sim (0.5, 3.0)$ and a uniform distribution $U \sim (0.4, 0.95)$, respectively. The relations between assets and threats, and between assets and countermeasures, were then instantiated according to a sparse assignment rule with locally bounded coverage (where 70% of threats and 80% of countermeasures were rigidly mapped

to a single asset, with the remaining fraction affecting exactly two interconnected assets), so that each scenario preserved the structural dimensions reported in Table 5 while remaining consistent with the asset–threat–countermeasure formulation introduced in Section 4.

It is worth mentioning that the use of synthetically generated instances was a deliberate methodological choice intended to support controlled, reproducible, and scalable benchmarking across multiple problem sizes and operational profiles. In addition, the availability of real-world reaction data is often limited by confidentiality, privacy, and operational-sensitivity constraints, especially when remediation workflows, defensive configurations, and incident telemetry are involved. For this reason, synthetic scenarios provide a practical basis for comparative experimentation, although they should not be interpreted as a replacement for later validation in production-realistic environments.

To obtain a broader view of the behavior of the compared approaches, the experimental campaign considers instances of different sizes and complexity levels. Thus, this design makes it possible to analyze the quality of the selected reactions and how the methods behave as the search space grows combinatorially. In the most demanding cases, the study considers environments with massive countermeasure spaces, which are particularly useful for examining scalability and execution time behavior.

Besides, the evaluated methods are executed under a common implementation framework so that the obtained results can be interpreted consistently. This common setting includes the use of comparable instances, homogeneous execution conditions, and the same reporting criteria for solution quality and execution time.

All methods were implemented in a common experimental environment using Python 3.13 and executed on an Apple M-Series ARM64 architecture running macOS 15. Unless otherwise stated, all executions were performed under homogeneous conditions, using the same candidate pools, instance definitions, and budget settings. The stochastic methods were run with fixed parameter settings throughout the study, namely a population of 50 candidates, a crossover rate of 0.8, a mutation probability of 0.1, and tournament selection of size 3 (for the GA), a pool of 20 antibodies undergoing clonal expansion over 200 maximum iterations with an adaptive affinity threshold (for the AIS), and a population of 50 individuals, an elite size of 2, a mutation rate of 0.05, a crossover rate of 0.8, 20 clones per cycle, and a genetic-clonal phase switch interval of 10 generations (for the Hybrid AIS-GA), while the stopping criterion for the hybrid strategy was fixed to 200 generations. Execution time was measured as wall-clock time in seconds using Python's native `time.time()` module, and all reported values correspond to runs performed under the same timing protocol.

Also, since several of the assessed approaches are stochastic in nature, the experiments are repeated multiple times in order to reduce the influence of random initialization on the final conclusions. This choice is particularly important for evolutionary and bio-inspired methods, whose outputs may vary across runs depending on the initialization of the population and the probabilistic behavior of the search operators. Repeated executions therefore provide a more robust basis for comparing the stability of the methods.

5.2. Compared decision strategies and baselines

At a high level, the assessed methods can be grouped into three distinct categories.

First, the study includes alternative decision strategies that act as comparison baselines. This category encompasses a Random search (acting as an absolute lower bound) alongside fast deterministic logic, such as Greedy ROI, Greedy Coverage, Greedy Incremental, and Knapsack approximation. These methods make it possible to assess whether the additional complexity of adaptive optimization is justified in practical terms, or whether simpler strategies are able to achieve competitive results.

Second, the study includes the foundational metaheuristic paradigms in isolation, namely the Standard GA and the Standard AIS. Evaluating these standard engines provides the baseline behavior for pure evolutionary and pure hyper-mutational immune dynamics, respectively, establishing a robust theoretical reference.

Third, the evaluation also includes a hybrid AIS-GA strategy intended to combine the crossover behavior of GA-based search with the diversification capacity of AIS-inspired search. Specifically, its main role is comparative, i.e., it is assessed alongside the standard paradigms and the deterministic baselines in order to better understand under which problem conditions more flexible search mechanisms provide practical gains.

From this perspective, the compared methods are not treated as isolated algorithms, but as representatives of different ways of addressing the countermeasure-selection problem. This design enables a broader and more informative view of the relative strengths and weaknesses of deterministic baselines, standard metaheuristics, and the proposed hybrid engine.

5.3. Evaluation metrics and analytical dimensions

The assessment of the compared methods is based on a combination of quality-oriented and efficiency-oriented metrics. The primary quality metric is the residual risk associated with the selected solution, since this value directly reflects how well the resulting countermeasure set protects the relevant assets. It is important to specify that lower values indicate better defensive solutions.

In addition to solution quality, execution time is considered a fundamental metric. This aspect is especially relevant in the reaction ecosystem, where the practical utility of a methodology depends on the quality of the selected response but also on the time required to compute it. For this reason, the experimental analysis pays particular attention to the computational trade-off between protection quality and execution time.

When appropriate, the study also considers complementary descriptive indicators, such as the variability of the obtained results across repeated runs and the convergence dynamics of the compared methods. These indicators provide additional insight into the robustness and scalability of the assessed approaches, allowing the analysis to go beyond isolated average values and to capture more stable performance tendencies.

To strengthen the empirical interpretation of the results, the experimental study is complemented with an in-depth distributional and variance analysis. Rather than relying solely on mean outcomes, this analysis evaluates the probability density of the solutions and their interquartile stability to determine whether the observed superiority of a method is consistently predictable or subject to severe random fluctuations. In this way, the evaluation moves from simple feasibility-oriented validation toward a highly systematic, multi-criteria comparative assessment.

5.4. ATT&CK/D3FEND operational profile

Besides the randomized operational profiles used for controlled benchmarking, the experimental methodology also includes one semi-realistic case study grounded in the ATT&CK/D3FEND knowledge resources already discussed in Section 2.2. Specifically, the purpose of this additional profile is to reduce the circularity risk associated with fully randomized dependency generation and to verify whether the comparative trends observed under the controlled formulation remain qualitatively consistent in a more semantically grounded setting.

The grounded profile was derived from a representative ransomware-oriented reaction scenario. Such a scenario was selected because it naturally combines multiple defensive requirements, including prevention, inspection, endpoint protection, containment, and recovery,

Table 4

ATT&CK-informed, D3FEND-aligned semi-realistic operational profile used as a case study. The profile is manually instantiated from a representative ransomware-oriented scenario.

ATT&CK tactic	Representative ATT&CK technique(s)	Mapped countermeasure(s)	Encoded relation in the profile
Initial Access	Phishing (e.g., Spearphishing Attachment or Link)	Antivirus, EDR	Prerequisite relation (Antivirus, EDR), reflecting the assumption that endpoint response is deployed over a baseline endpoint-protection layer.
Initial Access	Exploit Public-Facing Application	Patch_Management, Firewall	Synergistic pair {Patch_Management, Firewall}, since vulnerability reduction and network restriction complement each other in limiting externally exposed attack opportunities.
Execution	Command and Scripting Interpreter	Antivirus, EDR	Synergistic pair {Antivirus, EDR}, since malware prevention and endpoint detection/response provide complementary protection once malicious execution begins.
Command and Control	Application Layer Protocol	Firewall, IDS	Synergistic pair {Firewall, IDS}, since traffic restriction and traffic inspection reinforce each other in layered network defense against command-and-control communications.
Impact	Data Encrypted for Impact	EDR, Backup	Synergistic pair {EDR, Backup}, since endpoint containment and recovery capability jointly reduce the operational impact of ransomware activity.

and therefore provides an appropriate setting for operational dependencies among countermeasures. Starting from an ATT&CK-informed description of the adversarial behavior, the profile considers a small subset of representative ATT&CK tactics and techniques relevant to the scenario, including both phishing-driven and externally exposed entry points. The corresponding defensive actions were then associated with D3FEND-aligned defensive functions and mapped to the countermeasure vocabulary already used throughout this work.

Unlike the randomized profiles, the grounded profile was instantiated manually rather than sampled automatically. More specifically, only relations that could be justified through the attack–defense mapping and through plausible deployment dependencies among the selected controls were encoded into the operational profile. In this way, the prerequisite and synergy sets used in this sanity-check case are not artifacts of random generation, but structured assumptions derived from a representative operational scenario. Table 4 summarizes the grounded operational profile in terms of ATT&CK tactics, representative techniques, mapped defensive controls, and the corresponding relations encoded in the constrained formulation. This manually instantiated profile is then used in Section 6.2 as a targeted sanity-check case study within the same constrained evaluation framework, so that the dependency structure is grounded while the underlying benchmark instance remains unchanged.

6. Results

The primary objective of this section is to empirically evaluate the proposed asset–threat–countermeasure formulation under a common comparative setting, to analyze the behavior of alternative decision strategies over that formulation, and to assess whether the main constrained-performance trends remain qualitatively consistent under a manually grounded operational profile. To this end, the study considers both deterministic baselines and stochastic search methods, with particular attention to solution quality, execution time, variability, and scalability. To ensure a rigorous evaluation, the testbed was meticulously designed to subject the optimization engines to varying levels

of combinatorial complexity, spanning multiple synthetically generated network scenarios ranging from *Small* to *XLarge*.

The nomenclature labels assigned to the testbed instances directly denote the structural scale of the simulated threat landscape—specifically, the number of interconnected IT assets ($|A|$), simultaneous vulnerabilities or threats ($|T|$), and available candidate countermeasures ($|C|$). Table 5 details the exact volumetric parameters defining the search space for each evaluated instance.

As shown in Table 5, the *Small* scenario represents a localized sub-network with a highly constrained search space. Conversely, the *XLarge* environment simulates a massive enterprise-grade infrastructure scaling up to 400 assets and an arsenal of 1200 candidate countermeasures. This combinatorial expansion of the search space was explicitly designed to push the evaluated methods toward more demanding operating conditions.

A comprehensive comparative analysis was conducted across 8 evaluated algorithms. The selected methods were chosen to represent different families of combinatorial optimization approaches and to provide a broad comparative baseline for the countermeasure-selection problem. To provide an absolute performance floor, a *Random search* strategy was included as a sanity-check lower bound. To represent fast deterministic logic, three heuristic policies were evaluated, i.e., *Greedy ROI*, *Greedy Coverage*, and *Greedy Incremental*. In addition, because budget-constrained countermeasure selection is closely related to the 0–1 *Knapsack* problem, a classical Knapsack approximation was included as a reference from traditional combinatorial optimization.

In the stochastic domain, the *Standard GA* was selected as a representative evolutionary baseline, while the *Standard AIS* was included to isolate the hyper-mutational immune dynamics. Finally, testing these standard paradigms alongside *Hybrid AIS-GA* completes the comparative analysis of stochastic search behavior. Given the inherent stochastic nature of this latter group, each metaheuristic was executed 30 independent times per scenario using different random seeds in order to reduce the effect of random initialization and to assess the variability of the obtained results.

Table 5
Structural complexity of the evaluated network scenarios.

Scenario	Assets ($ A $)	Threats ($ T $)	Countermeasures ($ C $)
Small	15	30	40
Medium	50	120	150
Large	150	400	500
XLarge	400	1000	1200

Table 6
Mean Residual Risk obtained across representative unconstrained scenarios (lower values indicate higher security). For stochastic methods, the value represents the mean over 30 independent runs. The best overall result per instance is highlighted in **bold**, and the best metaheuristic result is underlined.

Algorithm	Small	Medium	Large	XLarge
<i>Deterministic Baselines (Zero Variance)</i>				
Random	0.214	2.769	4.384	8.912
Greedy ROI	0.045	0.812	1.250	2.104
Knapsack	0.490	0.654	0.973	2.628
Greedy Coverage	0.062	1.015	1.442	2.650
Greedy Incremental	0.012	0.301	0.410	0.850
<i>Stochastic Metaheuristics (Mean over 30 runs)</i>				
Standard GA	0.051	1.205	2.150	4.210
Standard AIS	0.038	0.950	1.320	3.015
Hybrid AIS-GA	<u>0.015</u>	<u>0.350</u>	<u>0.510</u>	<u>0.920</u>

6.1. Global performance and baseline efficacy

To establish a quantitative foundation for our analysis, Table 6 presents the exact Mean Residual Risk obtained by the 8 evaluated algorithms across the four scaling instances in an ideal, unconstrained configuration (i.e., operating without restrictive financial budgets or strict deployment limits).

A preliminary analysis of the numerical values in Table 6 reveals a counterintuitive empirical finding, i.e., within our specific, baseline risk assessment model, the Greedy Incremental strategy exhibits outstanding performance, achieving the lowest residual risk among all evaluated algorithms. That is, the rationale behind the superiority of the greedy algorithm in these initial tests lies in the mathematical nature of the baseline evaluation model. Without complex operational constraints, the objective function exhibits submodular-like properties (i.e., diminishing returns). This characteristic allows a sequential greedy search to inherently make locally optimal choices that directly approximate the global optimum without needing to explore diverse and suboptimal paths.

Given the baseline results in Table 6, the extended operational evaluation focuses on the strongest deterministic baseline (i.e., Greedy Incremental) and the most robust stochastic strategy (i.e., Hybrid AIS-GA). This decision makes it possible to study the impact of deployment dependencies and operational restrictions on the two most competitive paradigms without unnecessarily expanding the experimental space.

While the baseline residual risk formulation provides a useful reference point, real cyber-defense deployments often involve additional dependencies among countermeasures that cannot be captured through residual risk and budget alone. For this reason, a second group of experiments was conducted over the extended operational formulation introduced in Section 4.3. In this setting, each benchmark instance was evaluated under 7 randomized operational profiles, each profile defining a budget cap together with deployment dependencies in the form of prerequisite relations, mutual exclusions, and synergistic countermeasure interactions. This design makes it possible to analyze how the compared strategies behave when the countermeasure-selection problem moves beyond the baseline formulation and incorporates a more operationally constrained decision landscape.

The operational profiles reflect financial and technical deployment limitations by combining randomized budget caps with non-linear dependencies among countermeasures. The evaluated profiles include prerequisite relations (e.g., deploying an IDS requires a preexisting

Firewall, Endpoint Detection and Response (EDR) requires Antivirus), exclusion relations between conflicting tools, and synergistic reductions when complementary pairs are co-selected.

These interdependencies, together with the budget restrictions, produce a more difficult evaluation landscape than the one observed in the baseline formulation. In this setting, deterministic methods such as *Greedy Incremental* evaluate countermeasures sequentially and may therefore become more vulnerable to suboptimal portfolio constructions when prerequisite relations, exclusions, and interaction effects are present. By contrast, the *Hybrid AIS-GA* evaluates complete countermeasure portfolios and is therefore better suited to exploring combinations that remain compatible with the operational restrictions imposed by each profile.

To ensure absolute experimental reproducibility and maintain strict control over the computational overhead, the *Hybrid AIS-GA* was bounded by a stopping criterion of exactly 200 generations per execution, and was independently executed 30 times per profile to capture stochastic variance. From a temporal perspective, this 200-generation limit ensured that while the *Greedy Incremental* search resolved almost instantaneously (in the order of milliseconds), the *Hybrid AIS-GA* consistently converged within operationally viable timeframes for incident response—averaging under 1.0 s for *Medium* instances and bounding at approximately 6.0 s for the massive *XLarge* environments. The results obtained under the extended operational formulation introduced in Section 4.3 are summarized in Table 7, which reports the behavior of the two compared strategies across the scaling instances under the randomized operational profiles.

The descriptive results reported in Table 7 show that the behavior of the compared strategies changes substantially under the extended operational formulation. As the problem size increases, the *Greedy Incremental* strategy exhibits a clear deterioration in both mean performance and stability, particularly in the *Large* and *XLarge* instances, where the operational profiles introduce stronger budget restrictions and more intricate deployment dependencies. This trend suggests that sequential greedy selection becomes increasingly vulnerable when the quality of a countermeasure set depends not only on the isolated effect of each selected action, but also on compatibility relations, prerequisite structures, and synergistic interactions.

To rigorously validate these observations and confirm that the superiority of the *Hybrid AIS-GA* in this constrained setting is statistically significant rather than merely descriptive, we conducted a formal inferential analysis. Both *Greedy Incremental* and *Hybrid AIS-GA* were

Table 7

Results on the extended operational formulation across scaling instances. Each instance was evaluated over 30 independent runs; each run randomly instantiates one of 7 operational profile families (defining a budget cap together with prerequisite relations, mutual exclusions, and synergistic countermeasure interactions) using an independent seed, so that no two runs share an identical profile instance. For Greedy Incremental, the reported Mean $\pm$ Std summarizes the 30 distinct values obtained across these runs. For Hybrid AIS-GA, the reported statistics summarize the same 30 runs. The worst-case value corresponds to the highest per-run operational risk observed for each compared strategy.

Algorithm	Small	Medium	Large	XLarge
<i>Mean Residual Risk $\pm$ Standard Deviation</i>				
Greedy Incremental	0.145 $\pm$ 0.080	1.046 $\pm$ 0.637	1.950 $\pm$ 1.120	3.820 $\pm$ 2.450
Hybrid AIS-GA	0.052 $\pm$ 0.015	0.780 $\pm$ 0.180	1.050 $\pm$ 0.220	1.840 $\pm$ 0.380
<i>Worst-Case Scenario (Maximum Risk Spike)</i>				
Greedy Incremental	0.310	2.558	4.210	8.950
Hybrid AIS-GA	0.080	1.129	1.450	2.610

Table 8

Paired inferential statistics for operational controlled runs (Greedy vs Hybrid AIS-GA). Mean diff is computed as Greedy – Hybrid (positive values indicate lower residual risk for Hybrid). Statistics are computed on $n = 30$ paired observations per instance (each pair = both algorithms run on the same randomized operational profile and seed); pooled $N = 120$. W denotes the Wilcoxon signed-rank statistic, and r_{tb} is the rank-biserial correlation.

Instance	Mean diff [95% CI]	W	p -value	r_{tb}
Small	0.093 [0.062, 0.124]	452.0	1.2×10^{-5}	0.94
Medium	0.266 [0.032, 0.501]	345.0	0.0215	0.48
Large	0.900 [0.475, 1.325]	421.0	0.0002	0.81
XLarge	1.980 [1.050, 2.910]	430.0	8.5×10^{-5}	0.85
Global	0.810 [0.522, 1.098]	5850.0	1.1×10^{-10}	0.61

Note: The 30 runs per instance correspond to 30 independent executions; each execution randomly selects one of the 7 operational profiles and uses an independent RNG seed. For each execution we record a paired outcome by running both algorithms with the same profile and seed.

executed on the same randomized operational profile and RNG seed for each independent run, so that observations are paired at the run level: each paired sample is $(\text{Risk}_{\text{Greedy},i}, \text{Risk}_{\text{Hybrid},i})$. As detailed in Section 4.3, each operational profile is a parametric family whose budget, prerequisite, exclusion, and synergy components are re-sampled from the run's own seed; consequently, no two of the 30 runs are evaluated under an identical profile instance, and *Greedy Incremental* (while deterministic given a fixed profile instance) yields a distinct value on each run. We performed 30 independent runs per instance (each run samples one of the 7 randomized operational profiles with an independent seed), yielding $n = 30$ paired observations per instance and $N = 120$ when pooled across the four instance sizes. We adopted a Wilcoxon signed-rank test across matched profile-level outcomes; Table 8 reports the test statistics together with 95% confidence intervals for the mean differences and the rank-biserial correlation as an effect-size measure appropriate for the paired design.

The inferential statistics corroborate the descriptive trends. For every evaluated scale the two-sided Wilcoxon signed-rank test rejects the null hypothesis at $\alpha = 0.05$, and the reported rank-biserial correlations indicate large effect sizes favoring *Hybrid AIS-GA* (e.g., $r_{tb} \approx 0.85$ at *XLarge*). The global pooled test is highly significant ($p \approx 1.1 \times 10^{-10}$), and the 95% confidence intervals for the mean paired differences exclude zero in the major comparisons reported above, providing statistical validation that Hybrid AIS-GA attains lower residual risk than Greedy Incremental under the tested operational constraints.

Ultimately, the *Hybrid AIS-GA* strategy achieves lower mean Risk_{op} values, noticeably smaller variability, and a statistically validated operational advantage across all evaluated scales. These results indicate that, under the extended operational formulation, more flexible search dynamics provide a practical advantage by exploring countermeasure portfolios more holistically and by adapting more effectively to the constrained decision landscape. Rather than supporting a universal superiority claim for any single optimization family, this evaluation reinforces the broader conclusion of the article: the practical value of a decision strategy depends strongly on the structure of the countermeasure selection problem and the operational restrictions under which it is solved.

6.2. ATT&CK/D3FEND-informed case study

To complement the randomized constrained evaluation, this subsection presents a targeted sanity-check experiment using the ATT&CK/D3FEND-informed operational profile described in Section 5.4. The goal is not to introduce a second full benchmark campaign, but to verify whether the qualitative constrained-performance trend persists when the dependency structure is no longer sampled at random and is instead manually grounded in structured security knowledge.

For this purpose, we selected one representative Medium-scale benchmark instance from the same synthetic testbed and preserved its original asset, threat, and countermeasure structures. Hence, the evaluation framework remains identical to the constrained formulation of Section 4.3, and the only modified element is the operational profile itself. In this way, the experiment directly isolates the concern that the observed Hybrid AIS-GA advantage could otherwise be interpreted as an artifact of randomized dependency generation.

Under this grounded profile, Greedy Incremental was executed once, since it is deterministic, whereas Hybrid AIS-GA was executed 30 times using different random seeds. The resulting comparison therefore remains deliberately small and controlled, and should be interpreted as an external-plausibility check rather than as a replacement for the main randomized constrained study.

Table 9 reports the results obtained under this grounded profile. Greedy Incremental achieved an operational risk of 0.6861 with an execution time of 0.1144 s, whereas Hybrid AIS-GA obtained a mean operational risk of 0.4811 ± 0.0276 over 30 runs, with a mean execution time of 1.9337 ± 0.0700 s. Although the deterministic heuristic remains substantially faster, the hybrid strategy again yields the stronger protection outcome under constrained deployment relations.

This result is important because it does not claim full real-world validation, but it does reduce the circularity risk associated with purely randomized operational profiles. The qualitative advantage of Hybrid AIS-GA remains visible when the prerequisite and synergy structure is manually anchored to plausible ATT&CK/D3FEND-inspired relations. This finding indicates that the constrained-performance trend observed

Table 9

Results obtained under the ATT&CK/D3FEND-informed grounded operational profile on a representative Medium instance. Lower values indicate better operational protection.

Strategy	Operational risk	Execution time (s)
Greedy Incremental	0.6861	0.1144
Hybrid AIS-GA	0.4811 ± 0.0276	1.9337 ± 0.0700

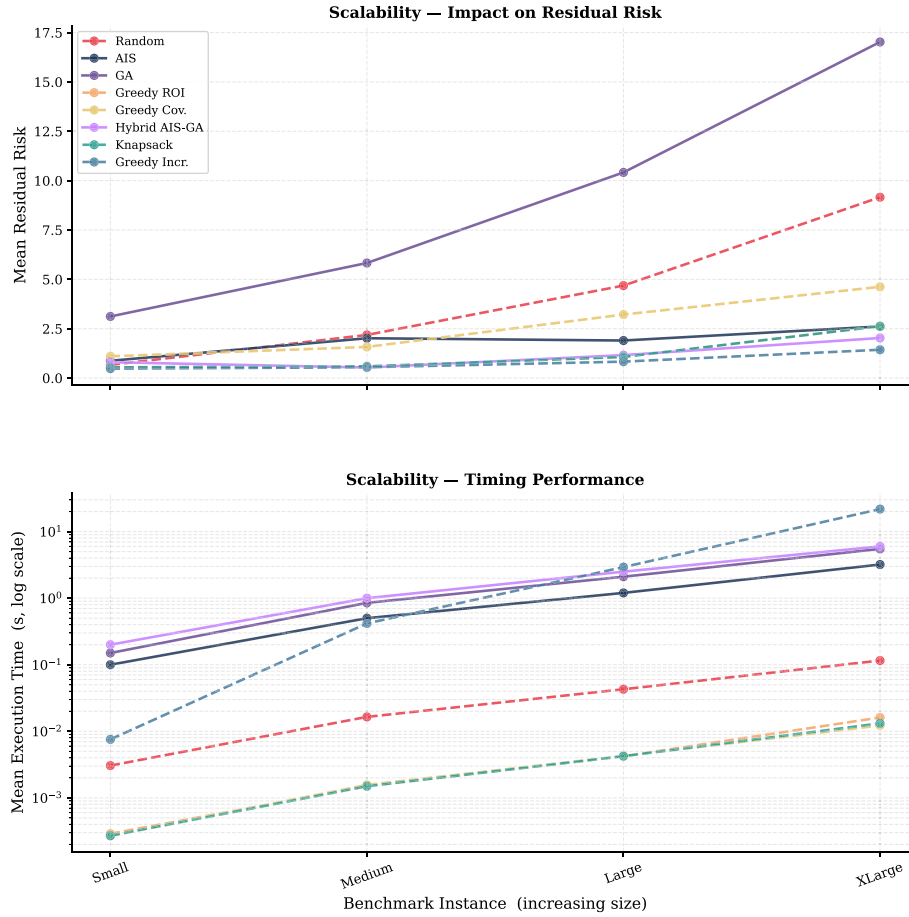


Fig. 3. Global scalability analysis across benchmark instances. **Up:** Mean Residual Risk growth as a function of network size. **Down:** Mean Execution Time mapping the computational cost on a logarithmic scale (10^{-3} to 10^1 seconds).

in the study cannot be attributed solely to the random generation of dependency structures.

6.3. Global scalability and computational trade-off

To illustrate the macroscopic behavior and scalability of all evaluated algorithms as the problem complexity expands, Fig. 3 presents the performance trends across the entire benchmark, ranging from the *Small* to the *XLarge* instances.

The top panel of Fig. 3 tracks the degradation of solution quality (Mean Residual Risk) as the problem scale increases. The Random baseline predictably exhibits the strongest growth in residual risk. Among the stochastic metaheuristics, the Standard GA shows a less favorable scaling pattern in the larger instances, which is consistent with a stronger tendency toward premature convergence as the search space expands. By contrast, the Hybrid AIS-GA maintains a flatter risk trajectory and remains closer to the strongest deterministic baselines, such as Greedy Incremental and the Knapsack approximation, even in the *XLarge* scenario. Under the evaluated conditions, this suggests that the hybrid strategy is able to preserve solution quality more effectively as the dimensionality of the problem grows.

The lower panel illustrates the corresponding computational cost via a logarithmic execution time scale. A clear visual bifurcation exists between the algorithmic families. Deterministic algorithms, particularly the *Greedy* variants, operate in the order of milliseconds (plotted in the 10^{-2} to 10^{-3} range), showcasing extreme computational efficiency. As expected, the evolutionary engines demand a higher computational budget. However, the *Hybrid AIS-GA* scales predictably, maintaining execution times within the 10^{-1} to 10^1 seconds range across all instances.

When considered together with the results obtained under the extended operational formulation, these trends summarize the central practical trade-off between solution quality and execution time. Deterministic heuristics remain extremely fast, operating in the order of milliseconds, but their behavior becomes less reliable when the problem includes stronger deployment dependencies and interaction effects. By contrast, the Hybrid AIS-GA requires a higher computational budget, yet it maintains a more stable balance between execution time and solution quality across the evaluated scales. From an operational perspective, this additional overhead appears compatible with time-sensitive cyber-response settings while offering more robust performance in the more constrained scenarios considered in this study.

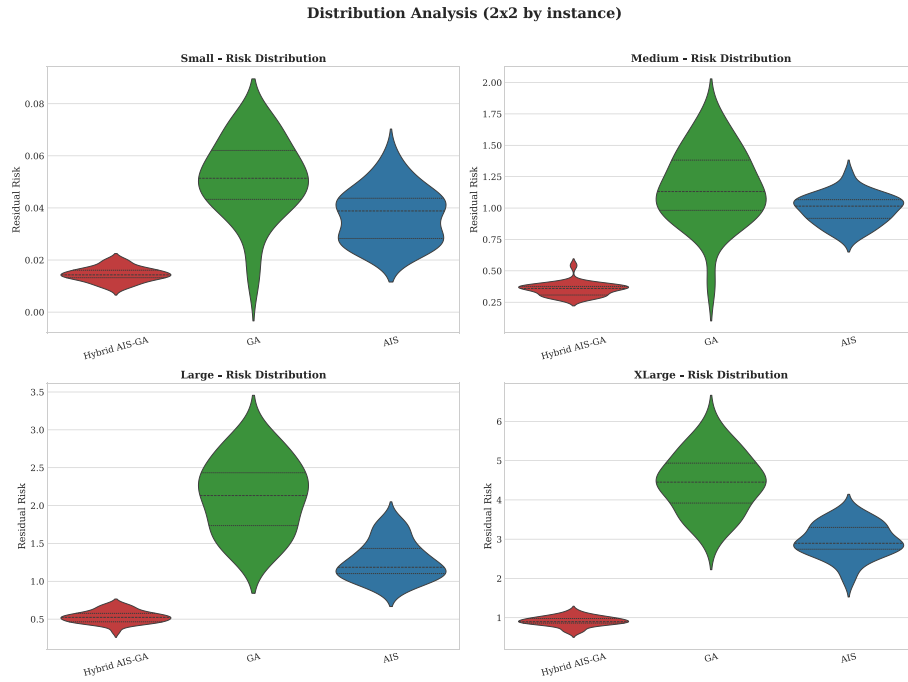


Fig. 4. residual risk distribution (2×2 by instance) for the stochastic methods (GA, AIS, Hybrid AIS-GA). Violin plots summarize central tendency and dispersion over repeated runs, showing how variability evolves from Small to XLarge scales. Lower values indicate better protection quality.

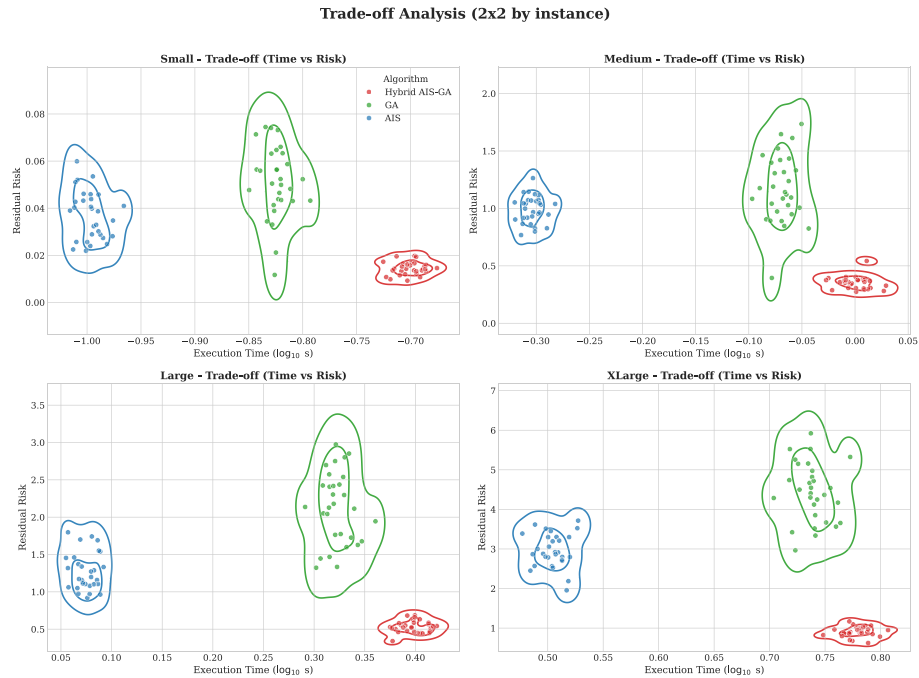


Fig. 5. Risk-time trade-off analysis (2×2 by instance) for GA, AIS, and Hybrid AIS-GA. Points correspond to repeated runs and contour lines represent local density. The horizontal axis reports execution time in $\log_{10}$ scale, enabling direct comparison of efficiency versus residual risk across problem sizes.

6.4. In-depth comparative analysis of the stochastic search methods

After the broader comparison presented in the previous subsections, the remainder of the analysis focuses on the internal behavior of the stochastic search methods. Since deterministic strategies yield a single fixed solution per instance and do not exhibit population dynamics over time, the following visual analysis concentrates on the Standard GA,

the Standard AIS, and the hybrid AIS-GA strategy. The purpose of this subsection is not to treat the hybrid approach as the sole contribution of the article, but to better understand how different stochastic search dynamics behave across problem scales and under the evaluation criteria adopted in this work.

Fig. 4, Fig. 5, Fig. 6, and Fig. 7 jointly detail the behavior of the evaluated stochastic methods across four representative problem scales

Convergence Analysis (2x2 by instance)

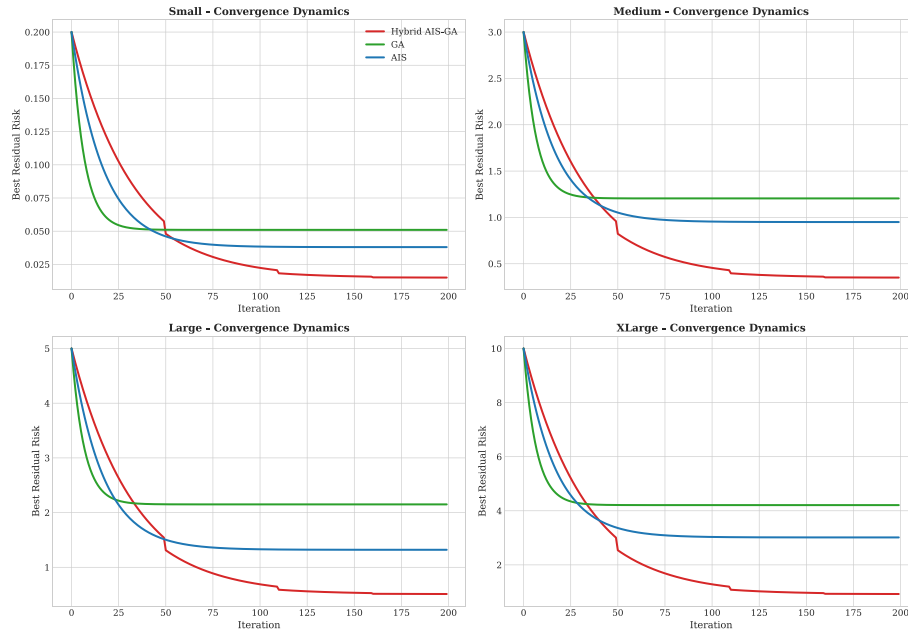


Fig. 6. Convergence dynamics (2×2 by instance) of stochastic methods along optimization iterations. Curves show the evolution of best residual risk, highlighting distinct exploration.

(Small, Medium, Large, and XLarge), each figure emphasizing one complementary analytical perspective.

To fully interpret the algorithmic dynamics captured in these four figures, the analysis is broken down across the same four core dimensions:

- Variance and statistical robustness (Fig. 4): The violin plots illustrate the probability density of the residual risk obtained across 30 runs. As the search space expands in the Large and XLarge scenarios, the distribution of the Standard GA (in green) becomes more elongated along the Y-axis, which indicates higher variance and lower stability. By contrast, the distribution of the Hybrid AIS-GA (in red) remains more concentrated around lower residual risk values. Under the evaluated conditions, this suggests a more stable search behavior as the problem size increases.
- Computational trade-off (Fig. 5): The bivariate Kernel Density Estimation (KDE) contours plot logarithmic execution time (X-axis) against residual risk (Y-axis). Among the evaluated stochastic methods, the Hybrid AIS-GA (in red) concentrates more clearly in the lower-risk region of the plot, while maintaining execution times within a bounded range. This visual pattern suggests a more favorable empirical balance between execution time and solution quality than the one observed for the Standard AIS.
- Search dynamics and local optima avoidance (Fig. 6): The empirical convergence curves provide additional insight into the different search dynamics of the stochastic methods. In the larger scenarios (Large, XLarge), the Standard GA (green line) shows a rapid initial descent followed by an early flattening pattern, which is consistent with premature convergence. By contrast, the Hybrid AIS-GA (red line) maintains a more sustained descent over the iterations, suggesting that the additional diversification introduced by the AIS-inspired component helps preserve search capacity in more complex instances.
- Multi-criteria fingerprint (Fig. 7): The radar charts summarize the overall algorithmic profiles by jointly mapping quality (risk reduction), efficiency (relative speed via logarithmic time normalization), and robustness (stability, as reflected in Fig. 4). While the Standard AIS extends more clearly toward the efficiency axis,

it remains less favorable in quality and robustness. By contrast, the Hybrid AIS-GA exhibits a more balanced profile across the evaluated instances. This fact suggests that its moderately higher execution time may be a reasonable trade-off for obtaining more stable solution quality in the tested scenarios.

7. Discussion and limitations

Before discussing the results in detail, this section is organized into two complementary parts. More specifically, Section 7.1 interprets the experimental findings from the perspective of adaptive countermeasure selection, emphasizing the role of the proposed modeling, the observed trade-offs between solution quality and execution time, and the comparative behavior of the evaluated strategies. Then, Section 7.2 discusses the main limitations of the study, clarifying the scope of the obtained results and the aspects that still require further validation in richer operational settings.

7.1. Discussion and operational implications

The extended experimental evaluation provides a much broader perspective on the behavior of adaptive countermeasure selection than the one available from earlier individual studies. Rather than considering only the feasibility of a single adaptive selector in isolation, the present work analyzes the framework under a systematic comparative setting, including standard metaheuristics and deterministic baselines.

A first relevant aspect concerns the value of the explicit modeling and problem formulation introduced in this article. By explicitly representing assets, threats, and countermeasures in a unified model, and by defining residual risk over their relations, the framework provides a highly expressive basis for evaluating candidate solutions. This explicit formulation makes the reasoning about protection transparent, supports direct interpretation of coverage effects, and offers a common mathematical ground on which different decision strategies can be benchmarked, thus clarifying the structure of the countermeasure selection problem itself (Nespoli et al., 2021b).

A second relevant finding of this study is that the behavior of the compared strategies depends strongly on the formulation being solved.

Radar Analysis (2x2 by instance)

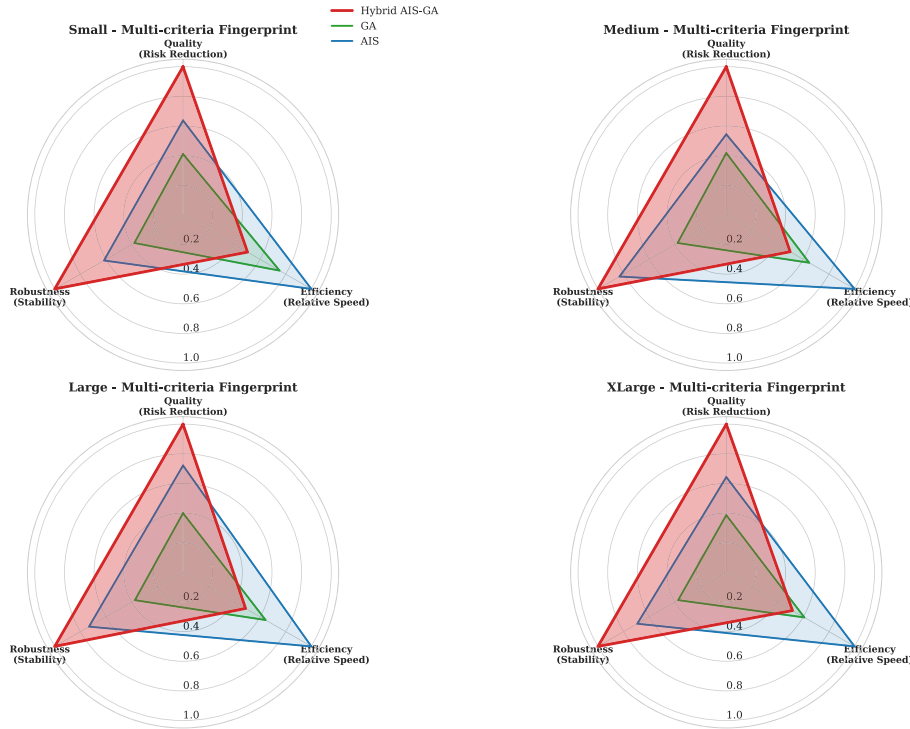


Fig. 7. Multi-criteria radar fingerprints (2 × 2 by instance) for stochastic methods, jointly comparing quality (risk reduction), efficiency (relative speed), and robustness (stability). Scores are normalized per instance to support visual comparison of algorithmic balance under different scalability conditions.

Under the baseline residual risk formulation, deterministic search (particularly the Greedy Incremental strategy) achieved highly competitive results, which suggests that simple sequential selection can be very effective when the evaluation landscape remains relatively smooth. However, this behavior changes under the extended operational formulation, where the introduction of budget caps, prerequisite relations, mutual exclusions, and synergistic interactions makes the quality of a candidate solution depend not only on the isolated value of each selected countermeasure, but also on the structure of the portfolio as a whole. In this setting, the results show a clear deterioration of greedy performance, especially as the problem scale increases, which confirms that the usefulness of an optimization strategy is closely linked to the operational structure of the defended scenario (Sethi and Verma, 2025).

The contribution of the present study should not be interpreted as evidence of universal superiority for a single optimization family. Rather, the results indicate that more flexible stochastic search strategies become comparatively more robust when the problem includes stronger deployment dependencies and interaction effects. In particular, the hybrid AIS-GA strategy exhibits more stable behavior across the evaluated scales and achieves lower values under the extended operational formulation, suggesting that broader exploration and portfolio-level adaptation are advantageous in more constrained settings. Therefore, the main lesson is that countermeasure selection should be addressed as a formulation-dependent decision problem, in which the practical value of each strategy emerges from the relation between solution quality, operational restrictions, and scalability.

Those results lead directly to a central operational trade-off, namely, solution quality versus execution time. In cyber defense, a strategy that consistently produces high-quality countermeasure sets may still be of limited practical value if its execution time is incompatible with the urgency of the incident response process (e.g., a ransomware campaign actively encrypting the filesystem (Alzahrani et al., 2025)). Conversely, a very fast strategy is not necessarily sufficient if it repeatedly yields poor-quality solutions in situations where there is more

time available to act (e.g., the remediation or patching of a known vulnerability (Sheng et al., 2025)). In this regard, the KDE contours and radar charts discussed in Section 6 suggest that the hybrid strategy provides a more favorable empirical balance between solution quality and execution time under the evaluated conditions. Although deterministic heuristics operate in the order of milliseconds, their behavior under the extended operational formulation becomes notably less reliable, particularly when deployment dependencies and interaction effects shape the quality of the selected portfolio. By contrast, the *Hybrid AIS-GA* strategy achieves more stable results while keeping execution times within a bounded range that remains operationally compatible with time-sensitive cyber response scenarios. Therefore, the additional computational overhead should be interpreted not as an excessive cost, but as a practically justified trade-off for obtaining more robust countermeasure sets in constrained environments. Ultimately, these results suggest that the value of the framework lies not in the universal superiority of a single optimization layer, but in its ability to support systematic and adaptive reaction against cyber attacks under different operational conditions (Iannucci et al., 2020).

Finally, from an operational perspective, the proposed framework remains effective since it combines structured remediation knowledge with an adaptive decision layer that is fully compatible with human supervision. In real-world security operations, administrators often require algorithmic support to navigate massive combinatorial spaces but do not necessarily relinquish final control over the selected response. In this sense, the framework acts as an advanced decision-support mechanism, capable of proposing highly optimized, constraint-compliant countermeasure portfolios that analysts can review and validate before definitive enforcement (Arif et al., 2025).

7.2. Limitations

It is important to note that the results of this article should be interpreted in light of certain limitations. A first limitation of this study is that the experimental assessment was conducted on synthetically

generated network instances and operational profiles. Although this choice enables controlled, reproducible, and scalable benchmarking across multiple problem sizes and constraint settings, it does not fully capture the operational complexity of real cyber defense environments. In particular, reaction against cyber attacks may be influenced by legacy infrastructure constraints, incomplete or noisy threat telemetry, changing network conditions, undocumented service dependencies, and organization-specific operational policies that are difficult to reproduce synthetically (Widelet et al., 2022). At the same time, the availability of real-world reaction data is often restricted by confidentiality, privacy, and operational-sensitivity constraints, which further complicates direct experimental validation. Therefore, the present results should be interpreted as evidence of comparative methodological validity under controlled conditions, rather than as a substitute for validation in production-realistic environments.

Second, the residual risk computation scheme relies on modeled quantities, i.e., countermeasure effectiveness, operational impact, financial cost, asset criticality, and threat probability. Although these quantities are necessary to evaluate candidate solutions in a principled way, in real operational settings they are often difficult to estimate with high precision and may vary across infrastructures, time periods, and administrative contexts. Consequently, the proposed framework should be interpreted as a structured decision-support model whose practical behavior depends on the realism and reliability of the underlying estimates, rather than as a formulation assuming perfectly known parameters. In this sense, the quality of the resulting recommendations is naturally conditioned by the accuracy of the threat intelligence, vulnerability data, and cost-effectiveness assessments used to populate the model (Darem et al., 2023).

Finally, the present work focuses primarily on quantifying solution quality, execution time, algorithmic stability, and combinatorial scalability. While these are fundamental dimensions for evaluating metaheuristics, they do not exhaust all the operational aspects relevant to practical cyber defense. Future evaluations could further investigate issues such as the human interpretability of the selected countermeasure sets, the engineering effort required to automate their deployment via orchestration platforms (e.g., SOAR), and the algorithmic resilience to intentionally deceptive or incomplete knowledge bases (Kotenko et al., 2022).

8. Conclusion and future work

This article addressed the problem of adaptive countermeasure selection for reaction against cyber attacks by combining an integrated conceptual basis with a revised modeling and optimization perspective. The work has shown that countermeasure selection cannot be treated only as an isolated optimization task, but should instead be formulated over an explicit representation of assets, threats, and countermeasures, together with a residual risk computation scheme capable of capturing the effect of selected defensive actions over the protected infrastructure.

From this perspective, the article contributes in two complementary directions. First, it builds on the main foundations established in the previous research line, including structured countermeasure representation, AIS-based adaptive selection, and GA-based parameter calibration. Second, it extends that foundation through a more explicit problem formulation and a broader comparative experimental evaluation involving improved optimization variants and baseline strategies. As a result, the paper provides a more systematic view of adaptive reaction against cyber attacks, both at the modeling level and at the empirical level.

The obtained results support two main conclusions. On the one hand, the proposed formulation offers a more expressive and scalable basis for evaluating candidate countermeasure sets, especially in scenarios with larger search spaces and more complex relations among

assets, threats, and defensive actions. On the other hand, the comparative analysis shows that the practical value of an optimization strategy depends strongly on the structure of the problem and on the trade-off between solution quality and execution time. The study highlights that simpler baseline strategies may remain highly competitive, and in some cases preferable, despite the availability of more sophisticated adaptive or bio-inspired approaches.

As future work, several directions remain open. A first one is the validation of the proposed framework in richer and more realistic operational settings, such as Cyber Ranges platforms (Grimaldi et al., 2024; Nespoli et al., 2025), production-inspired testbeds, or operational datasets, in order to assess its robustness under noisy telemetry, dynamic network conditions, heterogeneous legacy infrastructures, and real organizational constraints. A second direction is the incorporation of uncertainty-aware mechanisms, such as sensitivity analysis, interval-based parameterization, probabilistic confidence bounds, or fuzzy representations, with the objective of assessing the robustness of the framework under imprecise or partially incomplete inputs. In addition, future evaluations could further investigate complementary criteria such as interpretability, deployment effort, and resilience to incomplete knowledge. Finally, tighter integration with operational security platforms and orchestration environments would help assess the role of the framework in real decision-support workflows for reaction against cyber attacks.

CRedit authorship contribution statement

Pantaleone Nespoli: Writing – original draft, Visualization, Software, Methodology, Investigation. **Pedro Beltrán-López:** Writing – original draft, Visualization, Software, Methodology. **Giancarlo Sperli:** Writing – review & editing, Writing – original draft, Supervision, Formal analysis.

Declaration of competing interest

The authors declare the following financial interests/personal relationships which may be considered as potential competing interests: Pedro Beltrán-López reports financial support was provided by Fundación Séneca. Pedro Beltrán-López reports a relationship with Fundación Séneca that includes: funding grants. If there are other authors, they declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Acknowledgments

This work was supported by Seneca Foundation in Region of Murcia (Spain) (22943/FPI/25), co-funded by Scorpion Cybertechnologies.

Data availability

Data will be made available on request.

References

- Alzahrani, S., Xiao, Y., Asiri, S., Zheng, J., Li, T., 2025. A survey of ransomware detection methods. *IEEE Access* 13, 57943–57982. <http://dx.doi.org/10.1109/ACCESS.2025.3556187>.
- Arif, M., Badila, M., Warden, J.M., Rehman, A.U., 2025. A study of human factors toward compliance with organization's information security policy. *Inf. Secur. J.: A Glob. Perspect.* 34 (3), 235–250. <http://dx.doi.org/10.1080/19393555.2025.2457702>.
- Bashendy, M., Tantawy, A., Erradi, A., 2023. Intrusion response systems for cyber-physical systems: A comprehensive survey. *Comput. Secur.* 124, 102984. <http://dx.doi.org/10.1016/j.cose.2022.102984>, URL <https://www.sciencedirect.com/science/article/pii/S0167404822003765>.

- Boyes, H., Higgins, M.D., 2024. An overview of information and cyber security standards. *J. ICT Stand.* 12 (1), 95–134. <http://dx.doi.org/10.13052/jicts2245-800X.1215>.
- Bozorgchenani, A., Manolakis, D., Lalas, A., 2026. Multi-objective and deep Q-learning for countermeasure selection in 5G intrusion response systems. *Comput. Netw.* 112183. <http://dx.doi.org/10.1016/j.comnet.2026.112183>, URL <https://www.sciencedirect.com/science/article/pii/S1389128626001957>.
- Bozorgchenani, A., Zarakovitis, C.C., Chien, S.F., Ni, Q., Gougildis, A., Mallouli, W., Lim, H.S., 2024. Intrusion response systems for the 5G networks and beyond: A new joint security-vs-QoS optimization approach. *IEEE Trans. Netw. Sci. Eng.* 11 (3), 3039–3052. <http://dx.doi.org/10.1109/TNSE.2024.3358170>.
- Caiazz, T., Iannucci, S., Marini, V., Foschi, M., Torlone, R., 2026. From attack trees to timed stochastic games: A novel intrusion response approach. *Comput. Secur.* 164, 104834. <http://dx.doi.org/10.1016/j.cose.2026.104834>, URL <https://www.sciencedirect.com/science/article/pii/S0167404826000106>.
- Canonica, R., Sperli, G., 2023. Industrial cyber-physical systems protection: A methodological review. *Comput. Secur.* 135, 103531. <http://dx.doi.org/10.1016/j.cose.2023.103531>.
- Cardellini, V., Casalicchio, E., Iannucci, S., Lucantonio, M., Mittal, S., Panigrahi, D., Silvi, A., 2022. Irs-partition: An intrusion response system utilizing deep Q-networks and system partitions. *SoftwareX* 19, 101120. <http://dx.doi.org/10.1016/j.softx.2022.101120>, URL <https://www.sciencedirect.com/science/article/pii/S2352711022000796>.
- Darem, A.A., Alhashmi, A.A., Alkhalidi, T.M., Alashjaee, A.M., Alanazi, S.M., Ebad, S.A., 2023. Cyber threats classifications and countermeasures in banking and financial sector. *IEEE Access* 11, 125138–125158. <http://dx.doi.org/10.1109/ACCESS.2023.3327016>.
- Fernandes, D.A., Freire, M.M., Fazendeiro, P.A., Inácio, P.R., 2017. Applications of artificial immune systems to computer security: A survey. *J. Inf. Secur. Appl.* 35, 138–159. <http://dx.doi.org/10.1016/j.jisa.2017.06.007>, URL <https://www.sciencedirect.com/science/article/pii/S221421261630240X>.
- Gonzalez Granadillo, G., Débar, H., Jacob, G., Gaber, C., Achemlal, M., 2012. Individual countermeasure selection based on the return on response investment index. In: Kotenko, I., Skormin, V. (Eds.), *Computer Network Security*. Springer Berlin Heidelberg, Berlin, Heidelberg, pp. 156–170. http://dx.doi.org/10.1007/978-3-642-33704-8_14.
- Gonzalez-Granadillo, G., Doynikova, E., Garcia-Alfaro, J., Kotenko, I., Fedorchenko, A., 2020. Stateful RORI-based countermeasure selection using hypergraphs. *J. Inf. Secur. Appl.* 54, 102562. <http://dx.doi.org/10.1016/j.jisa.2020.102562>, URL <https://www.sciencedirect.com/science/article/pii/S221421262030716X>.
- Grimaldi, A., Ribollet, J., Nespoli, P., Garcia-Alfaro, J., 2024. Toward next-generation cyber range: A comparative study of training platforms. In: *Computer Security. ESORICS 2023 International Workshops*. Springer Nature Switzerland, Cham, pp. 271–290. http://dx.doi.org/10.1007/978-3-031-54129-2_16.
- Guo, Y., Zhang, H., Li, Z., Li, F., Fang, L., Yin, L., Cao, J., 2020. Decision-making for intrusion response: Which, where, in what order, and how long? In: *ICC 2020 - 2020 IEEE International Conference on Communications*. ICC, pp. 1–6. <http://dx.doi.org/10.1109/ICC40277.2020.9149083>.
- Hamad, M., Finkenzeller, A., Kühn, M., Roberts, A., Maennel, O., Prevelakis, V., Steinhorst, S., 2024. REACT: Autonomous intrusion response system for intelligent vehicles. *Comput. Secur.* 145, 104008. <http://dx.doi.org/10.1016/j.cose.2024.104008>, URL <https://www.sciencedirect.com/science/article/pii/S0167404824003134>.
- Iannucci, S., Cardellini, V., Barba, O.D., Banicescu, I., 2020. A hybrid model-free approach for the near-optimal intrusion response control of non-stationary systems. *Future Gener. Comput. Syst.* 109, 111–124. <http://dx.doi.org/10.1016/j.future.2020.03.018>, URL <https://www.sciencedirect.com/science/article/pii/S0167739X19320424>.
- Jorquera Valero, J.M., Sánchez Sánchez, P.M., Lekidis, A., Fernandez Hidalgo, J., Gil Pérez, M., Siddiqui, M.S., Huertas Celdrán, A., Martínez Pérez, G., 2021. Design of a security and trust framework for 5G multi-domain scenarios. *J. Netw. Syst. Manage.* 30 (1), 7. <http://dx.doi.org/10.1007/s10922-021-09623-7>, URL <https://doi.org/10.1007/s10922-021-09623-7>.
- Kaiser, F.K., Andris, L.J., Tennig, T.F., Iser, J.M., Wiens, M., Schultmann, F., 2022. Cyber threat intelligence enabled automated attack incident response. In: *2022 3rd International Conference on Next Generation Computing Applications (NextComp)*. pp. 1–6. <http://dx.doi.org/10.1109/NextComp55567.2022.9932254>.
- Kholidi, H.A., 2021. Autonomous mitigation of cyber risks in the Cyber-Physical Systems. *Future Gener. Comput. Syst.* 115, 171–187. <http://dx.doi.org/10.1016/j.future.2020.09.002>, URL <https://www.sciencedirect.com/science/article/pii/S0167739X19320680>.
- Kotenko, I.V., 2025. Artificial intelligence for cyber security: A new stage of confrontation in cyberspace. *Sci. Tech. Inf. Process.* 52 (5), 387–398. <http://dx.doi.org/10.3103/S0147688225700261>.
- Kotenko, I., Doynikova, E., Chechulin, A., Fedorchenko, A., 2018. AI- and metrics-based vulnerability-centric cyber security assessment and countermeasure selection. In: *Parkinson, S., Crampton, A., Hill, R. (Eds.), Guide To Vulnerability Analysis for Computer Networks and Systems: an Artificial Intelligence Approach*. Springer International Publishing, Cham, pp. 101–130.
- Kotenko, I., Saenko, I., Parashchuk, I., Doynikova, E., 2022. An approach for selecting countermeasures against harmful information based on uncertainty management. *Comput. Sci. Inf. Syst.* 19 (1), 415–433. <http://dx.doi.org/10.2298/CSIS210211057K>.
- Li, F., Li, Y., Leng, S., Guo, Y., Geng, K., Wang, Z., Fang, L., 2020. Dynamic countermeasures selection for multi-path attacks. *Comput. Secur.* 97, 101927. <http://dx.doi.org/10.1016/j.cose.2020.101927>, URL <https://www.sciencedirect.com/science/article/pii/S0167404820302030>.
- Li, F., Li, Y., Yang, Z., Guo, Y., Yin, L., Wang, Z., 2018. Selecting combined countermeasures for multi-attack paths in intrusion response system. In: *2018 27th International Conference on Computer Communication and Networks. ICCCN*, pp. 1–9. <http://dx.doi.org/10.1109/ICCCN.2018.8487417>.
- Luo, Z., 2025. Fog node intrusion detection and response based on SVMIF and INSGA-II algorithm. *Syst. Soft Comput.* 7, 200330. <http://dx.doi.org/10.1016/j.sasc.2025.200330>, URL <https://www.sciencedirect.com/science/article/pii/S2772941925001486>.
- Marchioro, T., Saroui, R., Olivereau, A., 2026. Network intrusion response systems: Towards standardized evaluation of intrusion response. In: *Laborde, R., Garcia-Alfaro, J., Blanc, G., Gimenez, P.-F., Kaluturage, H., Yanai, N., Shukla, A., Pirbhulal, S., Posegga, J., Lam, K.-Y. (Eds.), Computer Security. ESORICS 2025 International Workshops*. Springer Nature Switzerland, Cham, pp. 119–138. http://dx.doi.org/10.1007/978-3-032-16092-8_7.
- Nespoli, P., Albaladejo-González, M., Ruipérez-Valiente, J.A., Garcia-Alfaro, J., 2025. SCORPION cyber range: Fully customizable cyberexercises, gamification, and learning analytics to train cybersecurity competencies. *Human-Centric Comput. Inf. Sci.* 15, 67. <http://dx.doi.org/10.22967/HCCIS.2025.15.067>.
- Nespoli, P., Bernardez Molina, S., Beltrán-López, P., Gómez Mármol, F., 2026. Tackling Cyberattacks Through AI-Based Reactive Systems: A Holistic Review and Future Vision. *IEEE Commun. Surv. & Tutorials* 28, 1557–1596. <http://dx.doi.org/10.1109/COMST.2025.3583868>.
- Nespoli, P., Gomez Marmol, F., Kambourakis, G., 2021a. AISGA: Multi-objective parameters optimization for countermeasures selection through genetic algorithm. In: *Proceedings of the 16th International Conference on Availability, Reliability and Security. ARES '21, Association for Computing Machinery*, New York, NY, USA, <http://dx.doi.org/10.1145/3465481.3470074>.
- Nespoli, P., Gómez Mármol, F., Maestre Vidal, J., 2021b. Battling against cyberattacks: towards pre-standardization of countermeasures. *Clust. Comput.* 24 (1), 57–81. <http://dx.doi.org/10.1007/s10586-020-03198-9>.
- Nespoli, P., Gómez Mármol, F., Maestre Vidal, J., 2021c. A bio-inspired reaction against cyberattacks: AIS-powered optimal countermeasures selection. *IEEE Access* 9, 60971–60996. <http://dx.doi.org/10.1109/ACCESS.2021.3074021>.
- Phan, T.V., Bauschert, T., 2022. DeepAir: Deep reinforcement learning for adaptive intrusion response in software-defined networks. *IEEE Trans. Netw. Serv. Manag.* 19 (3), 2207–2218. <http://dx.doi.org/10.1109/TNSM.2022.3158468>.
- Phan, T.V., Gia Nguyen, T., 2022. FEAR: Federated cyber-attack reaction in distributed software-defined networks with deep Q-network. In: *2022 Wireless Telecommunications Symposium. WTS*, pp. 1–7. <http://dx.doi.org/10.1109/WTS53620.2022.9768169>.
- Randieri, C., Tomazzoli, C., 2025. Advancing Cyber Defense with Artificial Intelligence: State-of-the-Art Techniques and Future Directions. In: *Imoize, A.L., Kuznetsov, O., Lemeschko, O., Yermenko, O. (Eds.), Advancements in Cybersecurity: Next-Generation Systems and Applications*, first ed. CRC Press, p. 24.
- Reaney, M., McLaughlin, K., Grant, J., 2024. Network intrusion response using deep reinforcement learning in an aircraft IT-OT scenario. In: *Proceedings of the 19th International Conference on Availability, Reliability and Security. ARES '24, Association for Computing Machinery*, New York, NY, USA, <http://dx.doi.org/10.1145/3664476.3670917>.
- Rezapour, A., GhasemiGol, M., Takabi, D., 2024. A Systematic Mapping Study on Intrusion Response Systems. *IEEE Access* 12, 46524–46550. <http://dx.doi.org/10.1109/ACCESS.2024.3381998>.
- Sánchez-Zas, C., Larriva-Novo, X., Villagrà, V.A., Solera-Cotanilla, S., Sanz-Rodrigo, M., 2026. Dynamic characterisation of cyberattacks based on the MITRE ATT&CK framework applied to the optimisation of a mitigation selection process. *Future Gener. Comput. Syst.* 177, 108272. <http://dx.doi.org/10.1016/j.future.2025.108272>, URL <https://www.sciencedirect.com/science/article/pii/S0167739X25005667>.
- Schlette, D., Caselli, M., Pernul, G., 2021. A comparative study on cyber threat intelligence: The security incident response perspective. *IEEE Commun. Surv. & Tutorials* 23 (4), 2525–2556. <http://dx.doi.org/10.1109/COMST.2021.3117338>.
- Sethi, M., Verma, V., 2025. Improving intrusion detection systems using reinforcement learning: Responding to new cyber attacks and threats. In: *2025 International Conference on Emerging Smart Computing and Informatics. ESCI*, pp. 1–6. <http://dx.doi.org/10.1109/ESCI63694.2025.10988432>.
- Sheng, Z., Chen, Z., Gu, S., Huang, H., Gu, G., Huang, J., 2025. LLMs in software security: A survey of vulnerability detection techniques and insights. *ACM Comput. Surv.* 58 (5), <http://dx.doi.org/10.1145/3769082>.
- Skandylas, C., Khakpour, N., Cámara, J., 2022. Security countermeasure selection for component-based software-intensive systems. In: *2022 IEEE 22nd International Conference on Software Quality, Reliability and Security. QRS*, pp. 63–72. <http://dx.doi.org/10.1109/QRS57517.2022.00017>.

- Taherdoost, H., 2022. Understanding cybersecurity frameworks and information security standards—A review and comprehensive overview. *Electronics* 11 (14), <http://dx.doi.org/10.3390/electronics11142181>, URL <https://www.mdpi.com/2079-9292/11/14/2181>.
- Wang, W., Harrou, F., Bouyeddou, B., Senouci, S.-M., Sun, Y., 2022. Cyber-attacks detection in industrial systems using artificial intelligence-driven methods. *Int. J. Crit. Infrastruct. Prot.* 38 (C), <http://dx.doi.org/10.1016/j.ijcip.2022.100542>.
- Widell, W., Mukherjee, P., Ekstedt, M., 2022. Security countermeasures selection using the meta attack language and probabilistic attack graphs. *IEEE Access* 10, 89645–89662. <http://dx.doi.org/10.1109/ACCESS.2022.3200601>.
- Yue, Y., Tan, S., Tao, Y., Liu, N., Lü, J., 2025a. A non-Markovian game approach on labeled attack graphs for security decision-making in industrial control systems. *IEEE Trans. Inf. Forensics Secur.* 20, 10511–10524. <http://dx.doi.org/10.1109/TIFS.2025.3616599>.
- Yue, Y., Zhao, D., Zhou, Y., Xu, L., Tang, Y., Peng, H., 2025b. An intrusion response approach based on multi-objective optimization and deep Q network for industrial control systems. *Expert Syst. Appl.* 272, 126664. <http://dx.doi.org/10.1016/j.eswa.2025.126664>, URL <https://www.sciencedirect.com/science/article/pii/S0957417425002866>.